



File No.: EXP202101565

IMI Reference: A56ID 318964 - A60DD 432357 - Case Register 321773

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint on August 5, 2021, with the data protection authority of Bavaria (Bavarian Lander Office for Data Protection Supervision). The complaint is directed against OPEN BANK, S.A. with NIF A-28021079 (hereinafter, OPENBANK). The reasons on which the complaint is based are as follows:

The banking entity OPENBANK has requested the complainant to prove the origin of several amounts received in their bank account, in compliance with anti-money laundering regulations. However, no mechanism has been offered to facilitate this information encrypted or through direct upload on the web portal. The only valid option has been sending via email.

Along with the notification, the following is attached:

- Copy of an email sent from the address ***EMAIL.1 to ***EMAIL.2 (hereinafter, the complainant's email) dated July 7, 2021. In this email, the complainant is requested to provide the necessary documentation to prove the origin of the funds of three deposits made by the complainant, in compliance with anti-money laundering and counter-terrorism financing legislation; and it is indicated that, in the event of not receiving this documentation within 15 days, OPENBANK must block the execution of new payments in their account in accordance with current regulations.
- Copy of an email sent from the complainant's email to ***EMAIL.1 dated July 10, 2021. In this email, the complainant indicates that they are providing the corresponding documentation for the year 2019 under protest via an unencrypted email because, as stated in a phone conversation, there is no possibility of sending that documentation electronically in any other way.
- Automatic response to the previous email of July 10, 2021 sent from ***EMAIL.3 to the complainant indicating that their email has been received and they will respond soon.

SECOND: Through the "Internal Market Information System" (hereinafter IMI), regulated by Regulation (EU) No. 1024/2012 of the European Parliament and of the Council, of October 25, 2012 (IMI Regulation), whose objective is to promote the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Cross-border administrative cooperation, mutual assistance among member states, and the exchange of information, the aforementioned complaint was transmitted on August 24, 2021, and was registered with the Spanish Agency for Data Protection (AEPD) on August 30, 2021. The transfer of this complaint to the AEPD is carried out in accordance with the provisions of Article 56 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the Protection of Natural Persons with regard to the Processing of Personal Data and the Free Movement of such Data (hereinafter, GDPR), taking into account its cross-border nature and that this Agency is competent to act as the lead supervisory authority, given that OPENBANK has its registered office and main establishment in Spain.

The data processing carried out affects individuals in several member states. According to the information incorporated into the IMI System, in accordance with the provisions of Article 60 of the GDPR, it acts as an "interested supervisory authority," in addition to the German data protection authority of Bavaria, the authorities of the Netherlands, Portugal, and the German authorities of North Rhine-Westphalia, Hesse, Berlin, and Baden-Württemberg. All of them under Article 4.22.b) of the GDPR, given that the individuals residing in the territory of these supervisory authorities are substantially affected or are likely to be substantially affected by the processing subject to this

procedure.

THIRD: On September 9, 2021, in accordance with the then-applicable Article 64.3 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the complaint filed by the complainant was admitted for processing.

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the supervisory authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points: In response to an information request made by this Agency, OPENBANK provided, on May 19, 2022, among other information, the following:

1. Indication that OPENBANK has delegated the service of requesting information from clients to the entity Santander Global Operations, S.A. (hereinafter, SGO), which belongs to the Santander group, and that acts in this case as the data processor.
2. Indication that they have defined an internal procedure called "Protocol for Communications to Clients Regarding AML/CFT Alerts: Opening and Management of GAPS" to establish the way of acting of SGO when it is necessary to request information or supporting documentation for an unusual deposit. This procedure would apply in all countries where OPENBANK provides services under a free provision of services regime, including

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/77

Spain and Germany. As indicated in the document, this procedure consists of the fact that "the Openbank call center will contact the client to request such information at the mobile phone number registered in Openbank's database. Additionally, an email is sent to the address registered in our database from the mailbox ***EMAIL.4 to Spanish clients or from ***EMAIL.1 to German clients. In cases where the client requests information about other channels through which they can submit the required documentation, it is informed that they have the following options available: (i) by postal mail and (ii) in person at either of the two branches that Openbank has in Madrid." It is stated that a communication model for both contact channels is provided, which would be as follows:

Dear Client:

The reason for our communication is to inform you that Openbank is obligated, in compliance with current legislation, to know the economic activity and source of funds of its clients.

A. For a specific operation: In this communication, we request documentation that proves the source of the funds that you have deposited in Openbank on [date] for a total amount of [...] €. You may send us any document that justifies the source of the mentioned funds.

B. For regular operations: In this communication, we request documentation that proves the source of the funds that you have been depositing regularly from [...] until the date for a total amount of [...] €. You may send us any document that justifies the source of the mentioned funds.

You can send this documentation to the following email address: [***EMAIL.5 for Spanish clients or ***EMAIL.1 for German clients] indicating your full name in the email.

We inform you that Openbank, acting as the data controller of your personal data, will process the same for the fulfillment of the legal obligations to which Openbank is subject, adopting sufficient technical and organizational measures to ensure the security of the information. More information about your rights and data protection at [***URL.1 for Spanish clients or ***URL.2 for German clients]. We remain at your disposal for any clarifications you may need, best regards.

3. Regarding the measures taken to ensure the confidentiality of the documentation that the client sends to justify an unusual deposit, it is indicated, among other measures, the following:

Finally, considering the security we offer on our websites and mobile applications, and that Openbank is a 100% digital bank, we inform you that there are different processes in the entity, such as the contracting of mortgage loans, personal loans, or current accounts, that allow clients to send us

documentation through the private client area where they will be identified with their identity document and access key. In this regard, we would like to indicate that this functionality is implemented and operational to comply with the obligation of AML/CFT to apply measures to ensure Openbank's knowledge of its clients and to ensure that the documents, data, and information available are up to date.

We attach as an example Annex V: KYC Update Flow and Client Documentation.

Screenshots of the client knowledge form are provided, showing that at the end of completing the form, the option to update the documents of "Economic Activity Document" and "Address Verification" is offered by uploading them at that moment.

4. As "Annex IV: Contractual Support of the Service Provided by SGO," a copy of a document titled "ANNEX 12 ANTI-MONEY LAUNDERING SERVICE" is provided, indicating that it is an annex to the framework service contract between OPENBANK (as client) and SGO (as provider) signed on January 1, 2020, for a term of one year, renewable for annual periods. This annex is dated October 16, 2020, and its purpose is "the provision by the Provider to the Client of a Back Office service for activities related to the prevention of money laundering and financing of terrorism," with the following relevant content:

- In the first clause:

(...).

- In the fifth clause, regarding the protection of personal data, it is indicated that (...).

Additionally, in this fifth clause, it is indicated that (...).

And, in clause five.d) the following is indicated:

(...).

- In the sixth clause, regarding cybersecurity requirements, the following section on data transfers is included:

(...).

- In the eleventh clause, regarding subcontracting, the following is indicated concerning activities that cannot be subcontracted:

(...).

CONCLUSIONS OF THE PREVIOUS INVESTIGATION ACTIONS

1. Communications with clients regarding alerts for the prevention of money laundering and financing of terrorism are subcontracted to CGO both in Spain.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/77

as in Germany. They report that there is a protocol for making these communications, which indicates that, in these cases, the client is contacted using the phone number they have previously registered, and additionally, an email is sent to the email address they have previously registered.

2. According to this protocol, in the communication sent via email to request information from the client regarding alerts of money laundering, the channels that would be offered to the client for submitting documentation would be as follows: email, postal mail, or in person at the OPENBANK offices in Madrid.

3. OPENBANK has a secure method for uploading documents (through its website) for certain procedures (for example, to update the documents "Economic Activity Document" and "Address Verification" in the customer due diligence form). This method of uploading documents is not offered to the client within the protocol for money laundering alerts, according to what is indicated in the complaint.

FIFTH: On August 26, 2022, the Director of the AEPD adopted a draft decision to initiate sanctioning proceedings. Following the process established in Article 60 of the GDPR, on August 30, 2022, this draft decision was transmitted through the IMI system, and the interested authorities were informed that they had four weeks from that moment to submit relevant and justified objections. Within the deadline for this purpose, the interested supervisory authorities did not submit any relevant and

justified objections, so it was considered that all authorities agreed with this draft decision and were bound by it, in accordance with the provisions of paragraph 6 of Article 60 of the GDPR.

This draft decision was notified to OPENBANK in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP) on August 29, 2022, as stated in the acknowledgment of receipt in the file.

SIXTH: On October 3, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against OPENBANK, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 25 of the GDPR, classified under Article 83.4 of the GDPR, as well as for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR. In this Initiation Agreement, OPENBANK was informed that it had a period of ten days to submit allegations.

This Initiation Agreement, which was notified to OPENBANK in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was recorded on October 3, 2022, as stated in the acknowledgment of receipt in the file.

SEVENTH: On October 6, 2022, OPENBANK submitted a written request for an extension of the deadline to present allegations and for a copy of the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/77

EIGHTH: On October 14, 2022, the instructing body of the procedure agreed to extend the deadline requested for a maximum of five days, in accordance with the provisions of Article 32.1 of the LPACAP, and that a copy of the file be sent to OPENBANK.

The aforementioned agreement was notified to OPENBANK on October 14, 2022, as evidenced by the acknowledgment of receipt in the file.

NINTH: On October 26, 2022, a written submission from OPENBANK was received by this Agency, in due time and form, in which it presented allegations against the Initiation Agreement, accompanied by the following documentation:

- 1.- Document "Protocol for client communications regarding alerts for AML/CFT: OPENING AND MANAGEMENT OF GAPS (March 2021 version)."
- 2.- Document "Protocol for client communications regarding alerts for transactional monitoring for the prevention of money laundering and terrorist financing (AML/CFT) (October 2022 version)."
- 3.- Document "Certificate regarding sections 3.10 and 3.11 of the internal Manual of OPENBANK on AML/CFT."
- 4.- Document "Impact Assessment - Monitoring of sensitive clients and operations (August 2021 version)."
- 5.- Document "Impact Assessment - Monitoring of sensitive clients and operations (October 2022 version)."
- 6.- Document "Approval report regarding Santander Global Operations, S.A."
- 7.- Document "Internal security certificate issued by Santander Global Technology and Operations, S.L."
- 8.- Document "EVALUATION (...)"
- 9.- Document "VENDOR RISK ASSESSMENT - DP REPORT."
- 10.- Upload of documentation to the private client area.
- 11.- Images of "Section: Frequently Asked Questions on the Openbank website."
- 12.- Document "Certificate of document load availability, issued on October 21, 2022."
- 13.- Document "Certificate of the number of analyses of operations and impacted clients."

TENTH: On December 1, 2022, the instructing body of the procedure agreed to open a period for the presentation of evidence, considering incorporated the complaint filed by the claimant and its documentation, the documents obtained and generated during the admission phase of the complaint, and the report of prior investigative actions that are part of procedure E/09448/2021, considering reproduced for evidentiary purposes, the allegations against the initiation of the referenced sanctioning

procedure, submitted by OPENBANK, and the accompanying documentation.

On the same day, this Agency requested OPENBANK to submit the following information within ten working days:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/77

Provide documentary evidence regarding data protection by design and by default, for which OPEN BANK, S.A. is required to submit the data protection impact assessment in force on 07/07/2021, the date on which OPEN BANK, S.A. requested the sending of documentation to the claimant, since the documentation attached to the allegations of OPEN BANK, S.A. includes later versions, specifically, the modified versions from August 2021 and October 2022.

The opening of the evidence period was notified to OPENBANK in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP) on December 1, 2022, as evidenced by the acknowledgment of receipt in the file.

On December 19 and 28, 2022, OPENBANK submitted its response to the aforementioned request.

ELEVENTH: On April 11, 2023, the instructor of the procedure issued a diligence by which the document “Annual Report 2021” of the Santander Group was incorporated into the file, which includes the corporate structure of the Santander Group and its business volume. This report states that the total annual global business volume of Banco Santander, S.A. and its dependent companies (Santander Group) in the financial year prior to the commission of the infringement, financial year 2020, was 44,279 million euros (see pages 555 and 843 of the aforementioned “Annual Report 2021”).

TWELFTH: On May 23, 2023, the instructing body of the procedure issued a resolution proposal in which it was proposed, in accordance with the provisions of Articles 63 and 64 of the LPACAP, to impose a fine of 1,500,000 euros on OPENBANK for the infringement of Article 25 of the GDPR, and a fine of 1,000,000 euros for the infringement of Article 32 of the GDPR, both classified under Article 83.4 of the GDPR. It was also indicated that OPENBANK had a period of ten days to present allegations.

This resolution proposal, which was notified to OPENBANK in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on June 1, 2023, as evidenced by the acknowledgment of receipt in the file.

THIRTEENTH: On June 1, 2023, OPENBANK submitted a written request for an extension of the deadline to present allegations and for a copy of the file to be provided.

FOURTEENTH: On June 2, 2023, the instructing body of the procedure agreed to send OPENBANK a copy of the file, which was received via courier on June 8, 2023, as evidenced by the acknowledgment of receipt in the file.

FIFTEENTH: On June 5, 2023, the instructing body of the procedure denied the requested extension of the deadline to present allegations. The aforementioned agreement was notified to OPENBANK on the same day, as evidenced by the acknowledgment of receipt in the file.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/77

SIXTEENTH: On June 14, 2023, a written submission from OPENBANK was received by this Agency, in due time and form, in which it presented allegations against the proposed resolution. In these allegations, in summary, it stated that:

- The content of the proposed resolution is the same as the initiation agreement of the present sanctioning procedure, therefore it will reproduce the allegations already submitted.
- The regulations on the prevention of money laundering do not apply.

- There are no financial data.
- The so-called "high-level measures" are not required.
- The principle of non bis in idem is being violated, or alternatively, there would be a medial concurrence of infringements.
- OPENBANK complies with the principle of data protection by design.
- OPENBANK has not violated Article 32 of the GDPR.
- The principle of proportionality is being violated.

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: In the unsigned document accompanying the allegations to the initiation agreement of the present procedure, titled "PROTOCOL FOR COMMUNICATIONS TO CLIENTS REGARDING AML/CFT ALERTS: OPENING AND MANAGEMENT OF GAPS," it is indicated that the first approved version is from 03/04/2018 and that on 10/03/2021, a "Review, update, and modification of some deadlines (reduction of the same)" was carried out. In point 4 of the aforementioned document, it details:

"4. FOLLOW-UP OF THE GAP REQUEST AND ACCOUNT BLOCKING

The following process and deadlines are established to follow up on the request for information related to AML/CFT alerts and to establish account warnings, when appropriate:

D: SGO opens GAP requesting the Contact Center to contact the Client requesting information/documentation. If the request is urgent or if the size of the request does not fit in GAP, SGO will also send it by email to the Contact Center, documenting this point in GAP.

D+1: The Contact Center contacts the client and requests the information/documentation following the First Communication model from Annex I. Initially, the contact will be by telephone, and an email will also be sent to the client (See First Communication from Annex I) detailing the required documentation. If there is no valid email address, the request will be sent by postal mail.

The Contact Center will register in GAP both the sending of this communication and any contact with the client, or the impossibility of making such contact, and will reassign the GAP to SGO.

SGO reviews GAP and records in the GAP comment the date of the next review (D+15).

D+15: If the required documentation has not been received by this date, SGO will indicate to the Contact Center that it must reiterate the request for information to the client through a comment and the reassignment of the GAP.

D+16: The Contact Center contacts the client again, following the same process used in D+1 but in this case using the Second Communication from Annex I, in which the client is warned of the possibility of blocking." (...)

In Annex I of the aforementioned document, it is indicated:

"(...)"

SECOND: On July 7, 2021, an email was sent from the address ***EMAIL.1 to ***EMAIL.2. The content of the email is as follows (unofficial translation of the original in German):

"Dear Mr. A.A.A.,

The reason for our communication is to inform you that Openbank is obliged, according to current legislation, to know the economic activity and the origin of the funds of its clients. In this communication, we request the documents that prove the origin of the funds.

Amounts deposited in Openbank (account ending in XXXX).

- to (...)
- on (...)
- on (...)

Please send us documents that prove the origin of these funds.

You can send us any document that justifies the origin of these funds (for example, income tax, payslip, employment contract, sales contract if it is a real estate transaction).

We guarantee the absolute confidentiality of the documentation you send us.

If we do not receive the requested documentation within 15 days from the date of this notice,

Openbank may, in compliance with applicable regulations, prevent new deposits into your accounts. If you have any questions regarding this, please do not hesitate to contact us every day from 08:00 to 22:00 at ***PHONE.1.

Sincerely,

Your Openbank team”

THIRD: On July 10, 2021, an email was sent from the claimant's email to ***EMAIL.1. The content of the email is as follows (unofficial translation of the original in German):

“Dear Sir or Madam,

I have a sight deposit account at Openbank S.A./Madrid since last year. Now I have been asked to provide proof of sight deposits of more than XXXXX euros, but also of more than XXXX euros. I can understand this as part of the fight against "money laundering." However, the bank does not offer the possibility to securely upload the data, for example, through the client portal. In your

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/77

In this regard, I am compelled to transmit my personal data via a simple unencrypted email. Despite inquiring, I was only offered this option, which I was obliged to use.

I kindly request that you review the process from the perspective of data protection and, if applicable, take appropriate measures.

If you are not the competent authority, I kindly ask that you forward the matter to the appropriate party and send me a notification of submission.

Sincerely,

A.A.A.

FOURTH: On July 13, 2021, the claimant received an automatic response in their email sent by ***EMAIL.3. The content of the email is as follows (unofficial translation from the original in German):

“Thank you for your request. We confirm that it has been duly received and we will send you our response shortly.

Please note that our email hours are Monday to Sunday from 08:00 to 22:00.

This is an automated response. If you have any questions, please contact ***EMAIL.4.

Best regards,

OPENBANK”

FIFTH: Document 4 submitted by OPENBANK along with the allegations to the initiation agreement of the present sanctioning procedure is titled “Impact Assessment - Monitoring of Clients and Sensitive Operations,” is unsigned, and indicates that it is from August 2021. On page 41, it includes the following:

SIXTH: On May 19, 2022, in response to the information request made by this Agency, OPENBANK stated:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/77

1.- That it had delegated the service of information requests from clients to the entity Santander Global Operations, S.A. (SGO), which belongs to the Santander group, and that it acts in this case as the data processor, according to a contract dated October 16, 2020.

In the document “Annex IV: Contractual Support for the Service Provided by SGO” in the response to the information request from this Agency, in point 6.1 of the sixth clause of the “ANNEX 12 SERVICE FOR THE PREVENTION OF MONEY LAUNDERING TO THE FRAMEWORK CONTRACT FOR LEASING SERVICES AND/OR EXECUTION AND/OR DEVELOPMENT OF PROJECTS ENTERED

INTO BETWEEN SANTANDER GLOBAL OPERATIONS S.A. AND OPEN BANK, S.A. ENTERED INTO BETWEEN OPENBANK, S.A. AND SANTANDER GLOBAL OPERATIONS, S.A. ON JANUARY 1, 2020" it can be observed:

2.- That it had defined an internal procedure called "Protocol for Communications to Clients Regarding AML/CFT Alerts: Opening and Management of GAPS," whose purpose was to establish the update protocol for managing information requests from clients by Santander Global Technology and Operations (hereinafter, "SGTO"), an entity belonging to the Santander Group to which Openbank has delegated this service as the data processor.

3.- That this procedure for managing information requests from clients applied in all countries where OPENBANK provides services under the free provision of services regime, including Spain and Germany.

4.- That this procedure consisted of "the Openbank call center will contact the client to request such information at the mobile phone number registered in Openbank's database. Additionally, an email is sent to the address registered in our database from the mailbox of ***EMAIL.4 to Spanish clients or from ***EMAIL.1 to German clients. In cases where the client requests information about other channels through which they can send the required documentation, it is informed that they have the following options available: (i) by postal mail and (ii) in person at either of the two branches that Openbank has in Madrid."

5.- That the communication model for both contact channels was as follows: (...)

1. Clients may send via email attaching the encrypted documentation and the password by phone call.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/77

SEVENTH: Document 5 submitted by OPENBANK along with the allegations to the initiation agreement of the present sanctioning procedure is titled "Impact Assessment - Monitoring of Clients and Sensitive Operations," is unsigned, and indicates that it is from October 2022.

On page 4, in the section "1. EXECUTIVE SUMMARY," in the subsection "Name and Description of the Processing," it describes the data processing applicable to this case as follows: "Monitoring of clients and operations in compliance with AML/CFT regulations specifically established in Article 17 for financial entities to examine with special attention any fact or operation, regardless of its amount, that, by its nature, may be related to money laundering or the financing of terrorism, particularly any operation or pattern of behavior that is complex, unusual, or without an apparent economic or lawful purpose, or that shows signs of simulation or fraud."

On page 15 of the aforementioned document, the risk is classified as follows:

And on page 43 of the aforementioned document, the following is included:

EIGHTH: In the unsigned document accompanying the allegations to the initiation agreement of the present procedure, titled "PROTOCOL OF

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/77

COMMUNICATIONS TO CLIENTS REGARDING TRANSACTIONAL MONITORING ALERTS FOR THE PREVENTION OF MONEY LAUNDERING AND TERRORISM FINANCING (AML/CFT)", it is indicated that the first approved version is from 03/04/2018 and that on 10/03/2021, a "Review, update, and modification of some deadlines (reduction of the same)" was carried out. The third review of the document is indicated to have been conducted on 06/05/2022 and consisted of the "Review, update, and modification of the communications in Annex I", while the fourth review indicates it was conducted on 17/10/2022 and consisted of the "Review and update of the protocol with the aim of adapting it to the new process for uploading documentation via a private web, eliminating the need for the client to

send it to an email address. Document reviewed together with the contact center and Compliance Operations.” In point 4 of the aforementioned document, it is detailed:

“4. SENDING AND RECEIVING DOCUMENTATION BY CLIENTS

In all cases (clients from Spain and passport countries - Germany, Netherlands, and Portugal), clients will be informed to upload the required documentation to the designated space in the private area of the Openbank website, indicating, within the text field, the information that justifies the operations carried out. The contact center manager will assist clients when they have difficulties uploading the documentation. In case the client has forgotten their username and/or password to access the Openbank website, they will be informed of the steps to follow to reset it. Additionally, a help guide for managers has been prepared and information for clients has been incorporated into the FAQ section of the website.”

And in “Annex I - Communications to clients to request information and/or documentation due to a transactional monitoring alert for AML/CFT” it is explained:

“(…)”

NINTH: As of October 13, 2022, OPENBANK had enabled within the private area of the bank's website (which requires a username and password for access) a space for clients to provide the required documentation in compliance with the provisions of Article 6 of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism.

TENTH: During the trial period, OPENBANK provided an Excel file “DOCUMENTO_NUM._1.XLSX” without signature or date, in which on the tab “0.Control Sheet” it can be observed at the beginning in red “Data Privacy Impact Assessment (DPIA)”. And on the tab “2. Lifecycle” of this file, under the title “Data Capture”, it is contemplated in the section “Activities or processing operations” the “Extraction of the client's transactional operations from the Bank's core systems.” (...):

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/77

Life Cycle of Data Processing

Data Capture

Storage / Classification

Use / Processing

Data Transfer or Transfers to a Third Party

Destruction / Pseudonymization

Activities or Operations of Processing

Extraction of the client's transactional operations from the core systems of the Bank

Storage of data in internal fraud lists.

Monitoring and tracking of the client's transactional profile, through the analysis of their positions and operations in the various products contracted with Openbank and weighting

Data transfer of the client through the Editran tool

Data is not destroyed; it is stored indefinitely. However, the historical depth of the information consulted for the same client is limited.

Flow and Processed Data

Identifying Data

Economic, Financial, and Insurance Data

Identifying Data

Economic, Financial, and Insurance Data

Identifying Data

Economic, Financial, and Insurance Data

Identifying Data

Economic, Financial, and Insurance Data

N/A

Participants in the Activities or Operations of Processing (including Data Processors)

N/A

N/A

GEOBAN (in charge of alert monitoring)

BANCO SANTANDER SA (Second-level operational analysis)

Sepblac

N/A

Technology Involved in the Activities of Processing

Partenon

Office tools (Excel).

Norkom Tool

FIOC Application

Editran

N/A

The following form must collect all additional information that allows for an adequate identification of threats and assessment of the risks to which the affected personal data is exposed. It is necessary to indicate, broadly, how the life cycle of processing would be, from the moment the data is captured, how it is stored or classified, for what purpose it is used, the existence of transfers or transfers (whether to other national or international companies), and finally a description of how destruction is carried out.

General Information

2. Life Cycle of Data Processing

ELEVENTH: Banco Santander, S.A. has a direct participation of 100% in Open Bank, S.A. (see page 816 of the "2021 Annual Report" of the Santander Group).

The total annual global business volume of Banco Santander, S.A. and its dependent companies (Santander Group) in the financial year prior to the commission of the infringement, fiscal year 2020, was 44,279 million euros (see pages 555 and 843 of the "2021 Annual Report").

TWELFTH: The total number of clients of OPENBANK exceeds 1.7 million clients (Source: ***URL.3)

THIRTEENTH: The number of requests made by OPENBANK for operational analysis in compliance with Article 6 of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism, and the number of clients impacted as a result during the years 2020, 2021, and 2022 has been as follows, according to what is stated in Document 13 accompanying its allegations to the initiation agreement of the present sanctioning procedure:

LEGAL GROUNDS

I

Competence and Applicable Regulations

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 and 68.2

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/77

of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for the Protection of Data is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for the Protection of Data will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In this case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the

processing of personal data, since OPENBANK, through the entity Santander Global Operations, S.A. as the data processor, collects, stores, and communicates, among others, the following personal data of individuals: name, surname, tax identification number, email address, and the source of clients' income, among other processing activities.

OPENBANK carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

The GDPR provides, in its Article 56.1, for cases of cross-border processing, as provided in its Article 4.23), in relation to the competence of the main supervisory authority, that, without prejudice to the provisions of Article 55, the supervisory authority of the main establishment or of the only establishment of the controller or the processor shall be competent to act as the main supervisory authority for the cross-border processing carried out by such controller or processor in accordance with the procedure established in Article 60. In the case examined, as stated, OPENBANK has its main establishment in Spain, so the Spanish Agency for the Protection of Data is competent to act as the main supervisory authority.

For its part, Article 25 of the GDPR regulates data protection by design and by default, which the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, and, on the other hand, Article 32 of the GDPR regulates the security measures that must be adopted to ensure a level of security appropriate to the risk presented by the processing of personal data.

III

Claims Made

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/77

Regarding the claims made in response to the proposed resolution of this sanctioning procedure, a response is provided according to the order presented by OPENBANK.

FIRST.- GENERAL CONSIDERATIONS ABOUT THE CONTENT OF THE PROPOSED RESOLUTION

OPENBANK argues that the structure and content of the proposed resolution are not only extremely complex and difficult to follow, but that, as a consequence of all this, the AEPD incurs numerous contradictions.

In this regard, it argues that the proposed resolution dedicates the legal basis III to responding to the claims made by OPENBANK regarding the initiation agreement of this sanctioning procedure, to which it reproduces almost literally the claims made by OPENBANK, attempting to counter-argue each of them one by one, but that, subsequently, the proposed resolution reproduces in the legal bases IV and following, in practically literal form and with minimal alterations, the content of the aforementioned initiation agreement, without providing any reasoning or addition to what was already invoked by the Agency at the time of initiating the procedure.

It argues that what is stated in legal basis III of the proposed resolution is in open contradiction with what is mentioned starting from its legal basis IV, given that in the first of these bases the AEPD denies holding the argument or reasoning that it subsequently reproduces and uses to reaffirm its position in the following legal bases.

It indicates that this leads, first of all, to an obvious conclusion: if the reasoning of the AEPD is exactly the same as that maintained in the initiation agreement, OPENBANK can only reaffirm all and each of the claims previously made regarding the aforementioned agreement.

In this regard, this Agency acknowledges that it is possible that the wording of the legal bases following the one that responds to the claims presented by OPENBANK could be improved, which is why a new wording will be provided that simplifies the reading of the resolution, while improving the motivation regarding the commission of the infringement, as well as the sanction to be imposed and avoiding possible confusions.

SECOND.- REGARDING THE PREMISES HELD BY THE AEPD THROUGHOUT THE PROCEDURE OPENBANK, in its claims regarding the Initiation Agreement, pointed out how it was based on three essential arguments: (i) that OPENBANK was subject, regarding compliance with due diligence obligations, to the provisions of Article 32 of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism (hereinafter, the "LPBCFT") and 60.2 of its Development Regulation, approved by Royal Decree 304/2014, of May 5 (hereinafter, the "RPBCFT"); (ii) that the AEPD considered that the information requested by OPENBANK from the complainant had the consideration

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/77

of "financial data," which required the adoption of enhanced measures not assessed by OPENBANK; and (iii) that high-level security measures should be implemented. It is alleged that the proposed resolution does not contradict the arguments made by OPENBANK, but rather denies the application of the aforementioned premises by the Initiation Agreement, something that, in their opinion, directly contradicts the very fact of reading the proposal itself, given that the paragraphs transcribed by OPENBANK continue to appear, literally, in the legal grounds IV and subsequent ones of the same. In this regard, this Agency reiterates that:

- (i) the object of this procedure is not the violation of the provisions of the anti-money laundering regulations but the violation of the provisions of Articles 25 and 32 of the GDPR, regulations applicable to the protection of personal data of individuals, which falls under the competence of this Agency;
- (ii) the information requested by OPENBANK from the complainant does indeed qualify as "financial data," which required the application of a series of enhanced measures to effectively apply the principles of data protection and integrate the necessary guarantees in the processing to comply with the requirements of the GDPR and protect the rights of the data subjects (in accordance with the provisions of Article 25 of the GDPR), as well as the application of appropriate technical and organizational measures to ensure a level of security appropriate to the risk (in accordance with the provisions of Article 32 of the GDPR);
- (iii) that in this case it is not a matter of needing to implement "high-level" security measures, but rather that measures should be implemented that guarantee a level of security appropriate to the risk to the rights and freedoms of individuals.

However, this Agency acknowledges that it is possible that the wording of the legal grounds following the response to the allegations presented by OPENBANK could be improved, which is why a new wording will be provided that simplifies the reading of the resolution, while also improving the reasoning regarding the commission of the infringement and the sanction to be imposed, and avoiding possible confusions.

1. On the applicability of anti-money laundering regulations

OPENBANK alleges that, in relation to the alleged applicability to the due diligence obligations established in Article 32 of the LPBCFT, the proposed resolution establishes a premise: that the provisions of the anti-money laundering and counter-terrorism financing regulations are irrelevant in this case, given that (i) "the classification of the facts is not motivated by a violation of Articles 32 and 32 bis of Law 10/2010, as OPENBANK states in its allegations, but by Articles 25 and 32 of the GDPR"; (ii) "the object of this procedure is not whether or not the provisions of Article 32 or 32 bis of the LPBCFT have been violated, since it is not the competent authority for that, and the legal interest protected by the aforementioned regulations is different from the legal interest protected by the GDPR."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/77

of data protection”; and (iii) regarding OPENBANK's invocation of the reports from the AEPD itself “what cannot be done is, as OPENBANK intends, to use them to interpret the content of an article, 32.bis, in contrast to article 32, when article 32.bis did not exist at the date of issuance of such reports, having been added later by art. 3.15 of Royal Decree-Law 7/2021, of April 27, in force as of 29/04/2021.”

Regarding the first of the mentioned issues, OPENBANK considers that a mere reading of the legal basis IV of the Proposal for Resolution reveals how the AEPD continues to base all the accountability of OPENBANK on the alleged non-compliance by it of article 32 of the LPBCFT and how said provision refers exclusively to compliance by obligated entities in terms of preventing money laundering with respect to the provisions related to the obligations of special examination of operations and communication by initiation to the Executive Service of the Commission for the Prevention of Money Laundering and Monetary Offenses (hereinafter, “SEPBLAC”).

In this regard, this Agency acknowledges that it is possible that the wording of the legal bases following the one that responds to the allegations presented by OPENBANK could be improved, which is why a new wording will be provided that simplifies the reading of the resolution, while also improving the reasoning regarding the commission of the infringement and the sanction to be imposed and avoiding possible confusions.

Similarly, OPENBANK argues that the proposal for resolution errs in stating that the provisions in articles 32 and 32 bis of the LPBCFT are outside the competencies of the AEPD, since these are two norms that regulate the obligations of obligated subjects in terms of personal data protection and not the substantive aspects of the money laundering prevention regulations themselves. And that these provisions are configured as a special norm related to personal data protection within the framework of the money laundering prevention regulations, just as numerous sectoral norms include provisions for data protection regarding which the AEPD has never denied its competence, as they are merely the particularization for a specific case or sector of the norms contained in the GDPR and the LOPDGDD. OPENBANK indicates that the aforementioned provisions are those that specify the obligations that must be fulfilled by the obligated subjects to comply with the duties of proactive responsibility established in the personal data protection regulations concerning the processing of such data that must be carried out in compliance with the obligations established in the Law, and, regarding this case, concerning the fulfillment of the duty to know the origin of the funds established in the money laundering prevention regulations themselves.

That is to say, compliance with the principle of proactive responsibility, and in particular with the principle of privacy by design, is materialized in the adoption of the measures established by the LPBCFT itself, without it being acceptable to separate this law from the GDPR itself, as if they were independent legal norms referring to different realities. The LPBCFT indicates what those obligations are, differentiating clearly.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/77

evident (and in force at the time the events that led to this file occurred) between the obligations related to the treatments carried out in compliance with due diligence and those related to the treatments performed for the fulfillment of the special operations examination, so that in the present case, the application of what is provided in Article 32 bis of the LPBCFT is undeniable.

In this regard, this Agency wishes to point out that it cannot but agree with everything stated by OPENBANK in this sense. While clarifying that the management of regulatory compliance provided for in Article 25 of the GDPR is not limited to the application of the provisions of the LPBCFT that specify some of the obligations regarding data protection, reinforcing, moreover, some of the obligations related to certain treatments.

Thus, OPENBANK argues that compliance with the principle of privacy by design in the treatments carried out in compliance with Chapter II of the LPBCFT translates into Article 32 bis.4 of the law, which states that “obligated subjects must carry out a data protection impact assessment of the

treatments referred to in this article in order to adopt enhanced technical and organizational measures to ensure the integrity, confidentiality, and availability of personal data. Such measures must, in any case, guarantee the traceability of data access and communications."

And it is undeniable, in their opinion, that OPENBANK carried out the aforementioned data protection impact assessment in relation to the cited treatments, as it is also true that it did not conceive and apply this obligation as a static process, but as a dynamic process, with various assessments carried out by OPENBANK documented in the file, as well as the measures subsequently implemented by it, among which is currently the provision that information for compliance with due diligence obligations will be made available in the private area of the client provided by OPENBANK.

In this regard, this Agency wishes to point out that compliance with the principle of privacy by design in the treatments carried out in compliance with Chapter II of the LPBCFT translates into much more than what is indicated in Article 32 bis.4 of the law. All that is indicated in Article 25 of the GDPR applies to these treatments, just as it applies to all subjects included in its scope of application.

However, in the specific case of entities subject to the regime of the LPBCFT, the obligation to carry out an impact assessment in order to adopt enhanced measures to ensure the integrity, confidentiality, and availability of personal data (and at a minimum, to guarantee the traceability of data access and communications) is an additional obligation, due to the very nature of the treatments carried out in compliance with Chapter II of the LPBCFT, which require greater protection given the higher risk to the rights and freedoms of individuals.

It should also be noted that privacy by design is not limited to carrying out the data protection impact assessments referred to in the LPBCFT.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/77

In the present case,

it is evident that OPENBANK has failed to design the processing, as the activity of collecting customer data has not been included in the so-called "data processing lifecycle" of its Excel file for the data protection impact assessment document (submitted during the trial period of this procedure); therefore, since this activity was not even anticipated, appropriate technical and organizational measures have not been applied to effectively implement the principles of data protection (among others, confidentiality) and comply with the requirements of the GDPR and protect the rights of the data subjects.

Regarding the analyses conducted by OPENBANK in the documents titled "Impact Assessment - Monitoring of Customers and Sensitive Operations," in its version from August 2021, which was not even in effect at the time of the events subject to the complaint, which occurred in July 2021, it was only foreseen as a possibility that customers would send the information via encrypted message, sending the password through another channel. Furthermore, the aforementioned document mentions that "an internal request has been made for data subjects to upload documents directly through the section of the website, once they have logged in." However, it has been verified that the complainant was never given that option, neither in the initial communication sent by OPENBANK nor subsequently when they requested a secure alternative method for sending that communication. It was also verified that in the communication model sent to customers, none of these options were provided; it only mentioned the possibility of replying to the email sent without giving further indications on how that information could be protected.

It is curious that, despite not providing any sufficiently secure means for its customers to provide the information they were obligated to, both documents in their 2021 and 2022 versions acknowledge that the inherent risk of such processing was of high impact on the rights and freedoms of the data subjects.

And yet, it is only in the version from October 2022 that OPENBANK indicates that "customers will be identified by their ID and access key to the private customer area."

What is true is that the communication directed to the customer complied with what was provided in the document submitted by OPENBANK as a protocol for requesting documentation from customers under the LPBCFT, and the communication directed to customers did not indicate any means to provide that information, beyond the possibility of replying to the aforementioned email.

In any case, to comply with data protection by design and by default, it is not sufficient to simply have a protocol document or communication model; if upon reviewing such documents it is found that there was no proper anticipation of the appropriate technical and organizational measures to effectively implement the principles of data protection and integrate the necessary guarantees in the processing in order to comply with the requirements of the GDPR and protect the rights of the data subjects, as provided in Article 25.1 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/77

It is also not sufficient to have documents that establish protocols or models to follow if, in practice, appropriate measures are not provided to apply the principles of data protection during the processing, nor are the necessary guarantees integrated to comply with the requirements of the GDPR.

In the present case, it has been established that in July 2021, the claimant was requested to send certain information, which could have a significant impact on their rights and freedoms, via email, without further instructions on how to send such information through a secure channel.

It has also been established that the claimant had expressed their concern to the bank in this regard and had requested a secure means to share such information. However, due to the bank's refusal, they had no choice but to send the requested information via a simple email, to their dismay, despite having expressed their reservations. The claimant even explicitly requested that their concern be taken into account and that a secure means be provided in the future for sharing this type of information. However, in the documents from August 2021 submitted by OPENBANK along with its allegations regarding the initiation agreement, no other means is provided.

From the content of the documentation in the file, it has been established:

- That in "Annex I - Communications to clients to request information and/or documentation for PBC" of the document "PROTOCOL FOR CLIENT COMMUNICATIONS REGARDING PBC/FT ALERTS: OPENING AND MANAGEMENT OF GAPS," dated March 2021, in the first communication addressed to the client, in which they are requested to verify the source of the funds, no specific means is indicated by which they should provide such information to OPENBANK. Furthermore, in the second communication addressed to the client, no means is indicated for providing such documentation to the bank, but the text includes the threat that if the requested documentation is not received within the next 15 days, OPENBANK may prevent new deposits into their accounts.
- That on July 7, 2021, OPENBANK requested the claimant to send the documentation verifying the origin of certain funds, under the threat that in 15 days they could prevent new deposits into their account, without indicating any means by which they should provide such information.
- That on July 10, 2021, the claimant provided the requested documentation expressing their disagreement because when they inquired about how to send such information, they were told to do so via email, without further instructions. In this email sent, the claimant indicates that they do not consider it a secure means, that they are using this method because they felt compelled to do so, and they even provide as an example of a secure means the possibility of sending it "through the client portal," a possibility that was not provided to them by OPENBANK. They also request that they check the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/77

process from the perspective of data protection and take appropriate measures. However, this email

only received an automatic acknowledgment from the bank on July 13, 2021.

-

In the document "Impact Assessment - Monitoring of Clients and Sensitive Operations," dated August 2021, it is provided that the interested party may respond to the email with an encrypted message sending the password through another channel. It has also been requested that this could be done directly through the section of the website, once logged in.

-

In the document "Impact Assessment - Monitoring of Clients and Sensitive Operations," dated October 2022, it is provided that clients will authenticate themselves using their ID card and access key to the private client area.

-

In the document "PROTOCOL FOR COMMUNICATIONS TO CLIENTS REGARDING TRANSACTIONAL MONITORING ALERTS FOR THE PREVENTION OF MONEY LAUNDERING AND TERRORISM FINANCING (PBC/FT)," dated October 2022, it is indicated that clients will be informed to upload the documentation through the private area of the OPENBANK website. In "Annex I - Communications to Clients to Request Information and/or Documentation Due to a PBC/FT Transactional Monitoring Alert," it instructs the client to send the documentation through the "Client Area" of the OPENBANK website.

That is to say, the protocol in force at the time of the events (from March 2021) did not foresee providing information about the method of sending the requested documentation, despite the risks to the rights and freedoms present in such data processing.

In July 2021, the claimant draws attention to this issue in the email sent on July 10, 2021, to OPENBANK. However, the bank ignores it and does not even respond to their concern, which clearly pertained to a matter of personal data protection, which also evidences the lack of an internal procedure at OPENBANK to channel these issues.

In August 2021, OPENBANK foresees the possibility for clients to send the aforementioned documentation via an encrypted email and providing the password through another email (without specifying which one). It is indicated that the possibility of providing this documentation through the client area of the OPENBANK website was requested.

It is not until October 2022 that the communication protocols and the documents of the supposed impact assessment on this issue specifically incorporate that clients can submit the requested documentation through the OPENBANK website, logging into their client area.

That is to say, the solution to provide this information through the client area was adopted a year and a half after the action protocol of March 2021 was adopted and more than a year after the claimant had drawn attention to this specific issue and the document of the supposed impact assessment had already foreseen it as a possibility.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/77

which required monitoring.

All of this demonstrates that OPENBANK did not apply a data protection by design approach either prior to or during the processing, and therefore this allegation is dismissed.

OPENBANK claims that it is fully aware that the principle of privacy by design requires that enhanced measures to ensure the rights of data subjects be implemented prior to the actual processing, but that the obligation to obtain information from the data subject regarding the origin of funds is provided for in the LPBCFT, which has been in effect for more than eight years prior to the GDPR. Furthermore, OPENBANK was obligated to carry out the data processing referred to in this file long before the rules contained in the GDPR and the LOPDGDD were adopted or fully applied. Therefore, it is difficult to demand strict adherence to the principle (in the sense that the measures should have been prior to the processing), under penalty of failing to comply with its obligations regarding the prevention of money laundering and the financing of terrorism.

In this regard, this Agency wishes to point out that Organic Law 15/1999, of December 13, on the Protection of Personal Data was approved more than 10 years before the LPBCFT and that the LPBCFT itself contained in its original wording a reference to personal data protection regulations in its Article 32. There is no doubt that the subjects to whom the LPBCFT applied were fully subject to the provisions of the then-current personal data protection regulations. Regardless of the existence of a specific Article 32 of the LPBCFT for the processing in Chapter III of the aforementioned Law (which imposed a series of greater obligations on data controllers), this did not prevent the application of the personal data protection regulations in force at any given time for other processing: initially, the LOPD of 1999, until the GDPR and the LOPDGDD came into effect, which replaced it.

While it is true that the approach of the GDPR and the LOPDGDD was completely novel compared to previous data protection regulations, it is equally true that OPENBANK had more than enough time throughout the three years (six years if counted from the adoption of the GDPR text) that elapsed between the approval of the GDPR (April 2016) and its application (May 2018, which allowed for more than two years for preparation and adaptation to the GDPR) and the facts that gave rise to the complaint leading to this sanctioning procedure (July 2021) to adapt its processing to the provisions of Articles 25 and 32 of the GDPR (four years if considering that measures were only recently adopted for clients to share the requested information through their private area in October 2022).

Of course, it would have been impossible to have a data protection by design approach before carrying out the processing when it took place many years before the GDPR existed, but it is undeniable that the principle of data protection by design does not solely imply that the measures should have been prior to the processing, but rather that Article 25 of the GDPR itself states "both in the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/77

"at the moment of determining the means of processing as at the moment of the processing itself," that is, not only beforehand but throughout the duration of that processing and as long as the means of processing are determined, which is a decision that is also made over time, as circumstances and possibilities change at each moment.

Furthermore, it should be noted that, without undermining the legal obligations imposed by the LPBCFT, the legal obligations set forth in the RGPD are at least at the same level, especially since the latter protects a fundamental right. Obligations that must be fulfilled by OPENBANK, regardless of compliance with those arising from the LPBCFT; and this without the compliance with those provided in the latter regulation preventing compliance with those of the RGPD.

OPENBANK is focusing on its risks, on the risks to the organization if it does not comply with the LPBCFT, and not on the risks to the rights and freedoms of its clients regarding data protection.

Finally, OPENBANK argues that Article 32 of the LPBCFT is only applicable to the obligations contained in Chapter III. And this to the extent of urging the legislator to adopt a regulation that specifically establishes the scope of such obligations regarding personal data protection in relation to what is established in Chapter II of that Law, as was ultimately materialized in Article 32 bis of the LPBCFT, added by Article 3.15 of Royal Decree-Law 7/2021, of April 27. And that only in this way can the conclusion reached by Report 195/2013 of the Legal Office of this AEPD be interpreted when it states that "the interpretation that the high level of security referred to in Article 32.5 of Law 10/2010 is only required in relation to the files created to comply with the obligations established in Chapter III of the aforementioned Law must be considered consistent with the fact that the Law itself establishes certain limitations on the affected party in relation only to those files, that level being a further guarantee established as a counterbalance to the aforementioned limitations" and the fact that in Report 41/2018 the AEPD urged the legislator the need to regulate data protection obligations within the framework of compliance with due diligence duties and special examination of operations, recommending the drafting of differentiated regulations for each type of processing.

In summary, OPENBANK argues that the argument put forward by the AEPD should fall, since it bases the alleged non-compliance by OPENBANK with the principle of privacy by design and the

implementation of security measures on a regulation, Article 32 of the LPBCFT, which is not applicable to the case, as even indicated by the Agency itself.

In this regard, this Agency agrees that Article 32 of the LPBCFT is not applicable to the obligations of Chapter II of the LPBCFT, but rather Article 32 bis of the same, which is why a new wording will be given to the legal grounds following the one that responds to the allegations presented by OPENBANK.

IN CONCLUSION:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
25/77

1.- The management of compliance with Article 25 of the GDPR, privacy by design, is not exhausted by fulfilling the obligations regarding data protection set forth in the LPBCFT.

2.- The management of compliance with Article 25 of the GDPR is not exhausted by conducting data protection impact assessments.

3.- OPENBANK had not anticipated the processing activity consisting of the collection of financial data from clients for the prevention of money laundering.

4.- The data protection impact assessments carried out by the claimant at the time the events occurred did not include the processing activity consisting of the collection of financial data from clients for the prevention of money laundering.

5.- By not anticipating this activity, OPENBANK had not identified and assessed the risks to the rights and freedoms of clients present in such processing.

6.- By not identifying and assessing the risks, appropriate technical and organizational measures have not been established and applied to effectively implement the principles of data protection (among others, confidentiality) and to comply with the requirements of the GDPR and protect the rights of the data subjects (of all its clients).

7.- All of the above clearly demonstrates that OPENBANK did not fulfill its obligation to apply Article 25 of the GDPR, privacy by design, either before or during the processing activity.

2. Regarding the reference made by the AEPD to financial data

OPENBANK alleges that the proposed resolution enters into a clear contradiction, as it introduces two diametrically opposed considerations in two consecutive paragraphs of legal basis III, which seem to underpin its sanctioning reproach.

Thus, it is indicated that “it is not appropriate to determine the level of risk and the need to adopt appropriate security measures based solely on financial data, but according to what is provided by the applicable data protection regulations in the case, that is, depending on the type of processing, as well as specifically in terms of the prevention of money laundering,” which seems to reinforce the previously rebutted idea that it is the nature of the processing, and not the type of data, that justifies its reproach. But it immediately adds that “the factual circumstances of the present case determine that reinforced security measures must be adopted since the processing of the claimant's financial personal data presents a...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/77

high level of risk.” That is to say, it is the nature of the data, considered financial, and not the purpose of the processing, that justifies the adoption of measures that the AEPD considers unfulfilled.

In this regard, this Agency wishes to point out that the analysis and adoption of technical and organizational measures to effectively apply the principles of data protection and integrate the necessary guarantees to comply with the requirements of the GDPR and protect the rights of data subjects (Article 25 of the GDPR) and to apply appropriate technical and organizational measures to ensure a level of security adequate to the risk to the rights and freedoms of natural persons (Article 32

of the GDPR), should not be carried out solely by virtue of the nature or purpose of the processing being performed nor solely by virtue of the type of data being processed, as if they were exclusive aspects, but should be carried out taking into account all aspects that the processing in question may entail.

The analysis carried out by OPENBANK on the concept of “financial data” to determine whether the processing we are facing entails a higher risk and whether this category of data deserves special protection is incorrect, since it attempts to evaluate the concept of “financial data” separately from the LPBCFT regulations, when the need for a data protection impact assessment and the consequent adoption of reinforced measures that guarantee the integrity and confidentiality of personal data, as well as ensuring the traceability of access and communications of the data, are already established by the legal framework.

In compliance with the LPBCFT, obligated entities may process financial data, but not only data of this category; they also process personal data of various natures: identification, contact, or economic data (business, professional, investment...). Data protection in compliance with the LPBCFT cannot be limited by criteria applicable only to one of these data types, as OPENBANK attempts to reason, when what it seeks to protect is access to the information represented by all these personal data, not only individually, but also in their joint processing.

OPENBANK indicates that the above argument is reinforced by the fact that the legal basis IV of the proposed resolution again considers the reference to financial data made by Recital 28 of the GDPR as essential to determine the need for OPENBANK to have established an additional measure in the collection of data related to the origin of funds.

In this regard, this Agency wishes to point out that it does not understand the reference made to Recital 28 of the GDPR, since it deals with the pseudonymization of data. In any case, the reference to financial data is indeed decisive, given that these are data that deserve special protection as their processing entails a higher risk to the rights and freedoms of natural persons.

OPENBANK argues that, regarding the reference made by the AEPD to the Guidelines of the Article 29 Working Party (hereinafter, the “WP29”), it is sufficient to point out that the controversial processing does not imply any type of “assessment or scoring” of the data subjects nor its comparison with “a credit reference database or a...

27/77

database against money laundering and the financing of terrorism,” but only the obtaining of information regarding the origin of the funds corresponding to certain operations.

In this regard, this Agency wishes to remind of the content of the “Guidelines on the data protection impact assessment (DPIA) and to determine whether the processing ‘likely results in a high risk’ for the purposes of Regulation (EU) 2016/679,” as it pertains here: “In order to provide a more concrete set of processing operations that require a DPIA due to their inherent high risk (...) the following nine criteria should be considered: 1. Assessment or scoring, including profiling and prediction, especially of ‘aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, the situation or movements of the data subject’ (recitals 71 and 91). Some examples of this may include a financial institution investigating its clients in a credit reference database or in a database against money laundering and the financing of terrorism or regarding fraud...” (the emphasis is ours).

This Agency considers that the activity carried out by OPENBANK under the provisions of Chapter II of the LPBCFT, whereby clients are requested to provide the “documents that justify a certain income, as they will clarify the origin of the funds that have been deposited in the client’s account at OPENBANK,” does indeed fall within a financial institution investigating its clients in a possible database against money laundering and the financing of terrorism, which is why these operations likely entail a higher risk.

So much so that these operations likely entail a higher risk, that the same LPBCFT deemed it appropriate to incorporate the need to conduct a data protection impact assessment of the processing referred to in that article in order to adopt enhanced technical and organizational measures to ensure the integrity, confidentiality, and availability of personal data.

Furthermore, OPENBANK claims that the proposed resolution seems to indicate that OPENBANK has

not carried out any assessment of the impact of the processing on data protection, which directly contradicts the administrative file, in which it is recorded, as well as the measures adopted to mitigate the risks to data protection arising from the processing.

In this regard, this Agency wishes to remind that the object of the present procedure is not whether OPENBANK conducted a DPIA as required by Article 32 of the LPBCFT, but whether the organization had incorporated the principles of data protection by design and by default (Article 25 of the GDPR) and whether it had adopted appropriate security measures concerning the risk to the rights and freedoms of the data subjects (Article 32 of the GDPR).

In the present case, the lack of design of the processing by OPENBANK is evident, as the activity of collecting data from clients has not been included in the so-called "lifecycle of processing" of its Excel file of the data protection impact assessment document (submitted during the

28/77

trial period of the present procedure); therefore, as this activity is not even foreseen, appropriate technical and organizational measures have not been applied to effectively implement the principles of data protection (among others, confidentiality) and comply with the requirements of the GDPR and protect the rights of the data subjects.

Furthermore, this Agency reiterates what has already been stated in the allegation regarding the applicability of anti-money laundering regulations concerning the analysis of the content of communications sent to the complainant as well as the documentation provided in the file, all of which evidences that OPENBANK did not apply a data protection by design approach either before or during the processing.

OPENBANK claims that both the Manual of European Legislation on Data Protection and the AEPD Guide on Risk Management refer, when mentioning financial data, to data related to payment methods, even though the proposed resolution seems to categorically and unfoundedly deny this assertion.

In this regard, this Agency wishes to remind the content of Chapter 9.2 of the Manual of European Legislation on Data Protection, prepared by the Agency of the European Union for Fundamental Rights, the Council of Europe, the European Court of Human Rights, and the European Data Protection Supervisor, where it refers to "financial data": "Although financial data is not considered sensitive data under Convention 108 or the General Data Protection Regulation, its processing requires special guarantees to ensure the accuracy and security of the data. In particular, electronic payment systems need to incorporate data protection measures, that is, privacy or data protection by design and by default." The mention of privacy protection concerning electronic payment systems highlights their importance, but does not exclude that, similarly, other financial data may require special guarantees, as is the case here with the data collected under the provisions of Chapter II of the LPBCFT.

Regarding the Guide on Risk Management and Impact Assessment in Personal Data Processing by the AEPD, it differentiates between three types of economic data that must be assessed when determining the level of risk of a particular processing for the purpose of conducting the DPIA, distinguishing between these three categories of data:

- Data related to the "[e]conomic situation (e.g., without being exhaustive, personal income, monthly income, assets (movable/immovable property), employment situation)." These data are assigned a "medium risk."
- Data related to the "[f]inancial status (e.g., without being exhaustive, financial solvency, borrowing capacity, level of debt (personal loans, mortgages), solvency lists, defaults, assets (investment funds, generated returns, shares, accounts receivable, rents received, etc.), liabilities (expenses on food, housing, education, health, taxes, credit payments, credit card or personal expenses, etc.; or debts or obligations)." These data are also assigned a "medium risk."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/77

- “Payment method data (e.g., including but not limited to, credit cards and access information for virtual currency services).” In the case of this data, a “high risk” is indeed assigned. OPENBANK added in its allegations to the initiation agreement of the present sanctioning procedure that, in the criteria established by the AEPD for conducting a DPIA, it is stated in number 4 that “[t]reatments involving the use of special categories of data referred to in Article 9.1 of the GDPR, data related to criminal convictions or offenses referred to in Article 10 of the GDPR, or data that allow the determination of the financial situation or asset solvency or deduce information about individuals related to special categories of data.” And that the high risk that should justify the implementation of what said Agreement calls “high-level security measures” would only be applicable, in the opinion of OPENBANK, to the information that:

- Refers to payment methods, that is, related to data concerning those instruments that allow the data subject to acquire goods and services or enable them to settle debts they may have with third parties, aside from the non-exhaustive enumeration in the document.

- Allows determining the financial situation or solvency of a person.

In this regard, this Agency considers that the documentation requested by OPENBANK under the provisions of Chapter II of the LPBCFT, that is, “the documentary support related to the origin of a fund from their bank account (e.g., their payroll, employment contract, purchase contract if it is a real estate transaction, donation or inheritance, the invoice for the services provided that are satisfied by the beneficiary of those, the resolution declaring the receipt of a certain aid, etc.)” contains data related to the economic situation and financial status of the clients, which allows determining the financial situation or asset solvency of a person, and therefore requires greater protection.

Finally, OPENBANK argues that the conclusion of this Agency that “the data concerning three deposits in bank accounts must be considered as ‘financial data,’ and the information regarding the origin of these deposits, while not strictly financial in nature, is closely related to these bank movements, so that when information about the origin of the deposits is provided, it also reveals the movements in the bank account of the claimant that the activities giving rise to those deposits produce,” lacks any supporting evidence. And that, in any case, it is evident that the data classified as “financial” (deposits in bank accounts) would not be the same—and cannot be claimed to be so—as the other data (the information regarding the origin of these deposits), which the proposed resolution considers “closely related” to the bank movements.

In this regard, this Agency insists that it considers that the information regarding the origin of the deposits in the bank accounts of the clients is information that is closely related to such bank movements and contains data related to the economic situation and financial status of the clients.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/77

that allow for the determination of the financial situation or the asset solvency of a person, thus requiring greater protection in light of the risks to the rights and freedoms of the interested parties.

In this regard, we must point out that the financial personal data considered together (those provided by the client themselves, to which can be added those already held by the banking entity) can reveal multiple aspects about the client, such as the financial situation or asset solvency as we have indicated.

Thus, Opinion 1/15 of the Court of Justice (Grand Chamber) of July 26, 2017 establishes that, “128 On the other hand, even if some of the PNR data, considered in isolation, do not seem to reveal important information about the private life of the affected individuals, it is nonetheless true that, when considered together, such data can reveal, among other things, a complete travel itinerary, travel habits, existing relationships between two or more people as well as information about the economic situation of air passengers, their eating habits, or their state of health, and could even provide sensitive data about those passengers, as defined in Article 2, letter e), of the stipulated Agreement,” a risk that is also addressed by the CJEU ruling of August 1, 2022.

In any case, the LPBCFT itself recognizes that these are operations that likely entail a greater risk,

which is why it deemed it appropriate to incorporate the necessity of conducting a data protection impact assessment for the processing referred to in that article in order to adopt reinforced technical and organizational measures to ensure the integrity, confidentiality, and availability of personal data. IN CONCLUSION, the documentation requested by OPENBANK pursuant to the provisions of Chapter II of the LPBCFT, that is, "the documentary support related to the origin of a fund in your bank account (e.g., your payroll, employment contract, purchase contract if it is a real estate transaction, donation or inheritance, the invoice for the services rendered that are paid by the beneficiary thereof, the resolution declaring the receipt of a specific aid, etc.)" contains financial data related to the economic situation and financial status of the clients, which allow for the determination of the financial situation or the asset solvency of a person, thus their processing requires greater protection in light of the risks to the rights and freedoms of the interested parties.

Therefore, this allegation is dismissed.

3. On the enforceability of the so-called "high-level measures"

OPENBANK alleges that in the initiation agreement of the present sanctioning procedure, the enforceability of a "high" level of security was invoked, which was not required since the entry into force of the GDPR, and the proposed resolution merely indicates that it reproduced the text of Article 32 of the LPBCFT in its wording in force at the time the events occurred (which only reinforces what has already been indicated regarding its improper application). But it should also be added that, as much as

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
31/77

Unless otherwise indicated, the Initial Agreement and the Resolution Proposal did intend to apply the regime prior to the full implementation of the GDPR to OPENBANK in a mimetic manner, given that they refer to a measure, data encryption, which was expressly associated in that regulation with the so-called "high-level security measures."

At this point, the proposal again denies, although in its opinion there is evidence contradicting this in the file, that OPENBANK conducted an impact assessment of the processing on the rights of the data subjects, to determine the scope of the measures to be adopted, placing all blame on OPENBANK for the fact that only one of all its clients "drew [OPENBANK's] attention to this aspect," with the Agency considering that the response given by OPENBANK to that individual was not satisfactory.

This leads OPENBANK to question whether what the AEPD considers violated in this case is its duty to adopt technical and organizational measures aimed at mitigating the risks of processing, following an analysis of those risks through a data protection impact assessment, something that (in its opinion) the AEPD cannot deny that OPENBANK has carried out, or whether the object of the reproach from the AEPD is that it did not provide a response to the "concern" of the data subject that that Authority considers adequate, even though it is not possible to deny (in its opinion) that OPENBANK did respond to the request made.

In this regard, this Agency wishes to point out that the present sanctioning procedure refers solely and exclusively to the fact that OPENBANK did not apply, before and during the processing in question, data protection by design and by default, to ensure compliance with the principles enshrined by the GDPR (Article 25 of the GDPR), and did not adopt appropriate security measures based on the risk to protect the rights and freedoms of the data subjects (Article 32 of the GDPR), concerning the data processing subject to this procedure. It has also been indicated, moreover and further, that data protection by design is not exhausted by conducting an impact assessment.

The references made by this Agency to the LPBCFT should be understood solely to reinforce the violations of data protection regulations that this Agency would have established.

However, this Agency will provide a new wording for the subsequent legal grounds, as previously indicated.

Furthermore, this Agency wishes to point out that it has reviewed the measures adopted by OPENBANK regarding the information shared by users to comply with the obligations set forth by the

LPBCFT, and the reality is that clients were not provided with a secure means to facilitate the requested information, information that, in relation to the risks, could have a high impact on the rights and freedoms of its clients if materialized, as evidenced by the analysis conducted by OPENBANK in its documents entitled "Impact Assessment - Monitoring of Clients and Sensitive Operations," both in its August 2021 version and the October 2022 version. The fact that, even though the complaining party drew attention to this aspect, sending an email...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
32/77

to the address indicated for sending the financial documentation, without receiving any response from OPENBANK, further evidences the lack of awareness regarding this issue, given that no alternative means was provided for this purpose even when it was requested. That is to say, what this Agency considers violated in this case is not only that OPENBANK, at the time the events occurred, had not conducted an analysis prior to or during the processing in question that would ensure compliance with data protection principles, nor did it adopt appropriate measures commensurate with the risks to the rights and freedoms of the data subjects, but also that OPENBANK did not provide an adequate response to the "concern" of the data subject, all of which only highlights the failure to adopt data protection principles by design and by default.

Regarding the analyses conducted by OPENBANK in the documents titled "Impact Assessment - Monitoring of clients and sensitive operations," in its version from August 2021, which was not even in effect at the time of the events subject to the complaint, which took place in July 2021, it was only foreseen as a possibility that clients would send the information via encrypted message, sending the password through another channel. Even in the aforementioned document, it is mentioned that an internal request has been made for data subjects to be able to upload documents directly through the web section, once they have logged in. However, it has been verified that the complainant was never given that possibility, neither in the initial communication sent by OPENBANK nor subsequently when they requested a secure alternative for sending that communication. It was also verified that in the communication model sent to clients, none of these options were provided; it only mentioned the possibility of replying to the email sent without giving further indications on how that information could be protected.

It is curious that, despite not providing any sufficiently secure means for its clients to provide the information they were obligated to, both documents in their 2021 and 2022 versions acknowledge that the inherent risk of such processing was of high impact for the rights and freedoms of the data subjects.

And yet, it is only in the October 2022 version that OPENBANK indicates that "clients will identify themselves using their ID and access key to the private client area."

Finally, OPENBANK claims that it has in no case failed to respond to the concerns of the complainant nor can it be considered that there is any threat of any kind in that response, as indicated in the Proposal for Resolution. OPENBANK has merely pointed out that the absence of information regarding the origin of the funds in the disputed income will require OPENBANK to block the account, as there may be indications, due to non-compliance with anti-money laundering regulations, of the existence of illicit conduct by its client.

In this regard, this Agency wishes to point out that a satisfactory response has not been provided to the complainant regarding their concern, as they have not been...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
33/77

provided an adequate means to facilitate the information requested by OPENBANK under Chapter II of the LPBCFT.

In any case, it should be clarified at this moment that what OPENBANK refers to as "concern" on the part of the client is nothing more than a person, their client, who intends to enforce their Fundamental Right to the Protection of Personal Data.

Regarding whether there was any type of threat to the claimant, it is worth recalling the content of the communication model to clients, in effect in July 2021:

"□ Second communication: D+16

(...)

In the event that the requested documentation is not received within the next 15 days from the date of this communication, we inform you that Openbank may prevent new deposits into your accounts in compliance with the applicable regulations. (...)" (the underlining is ours)

And the email sent to the claimant on July 7, 2021, by OPENBANK stated the following:

"Dear Mr. A.A.A.

(...)

If the requested documentation is not received within 15 days from the date of this notice, Openbank may, in compliance with the applicable regulations, prevent new deposits into your accounts. (...)" (the underlining is ours)

The content of the communications sent by OPENBANK to clients (including the claimant), in which the submission of documentation is requested under Chapter II of the LPBCFT, contains a notice that if the aforementioned documentation is not submitted within 15 days, OPENBANK may prevent new deposits into their accounts.

The dictionary of the Royal Spanish Academy explains that "threat" is a "statement or act with which one threatens." While "to threaten" is defined as "said of something bad or harmful: to present itself as imminent for someone or something" and also "to give indications of going to suffer something bad or harmful."

Blocking new deposits from clients' accounts is, of course, something bad or harmful for those who suffer it, no matter how much OPENBANK claims it is "because there may be indications, due to non-compliance with anti-money laundering regulations, of the existence of illicit conduct in their client."

Including that information in communications directed to clients causes them to send the requested documentation even if they are not provided with appropriate means to do so (as the claimant should have done), out of fear of the possible unfavorable consequences for them, in this case, the blocking of their accounts.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

34/77

For all the above, this allegation is dismissed.

THIRD.- REGARDING THE VIOLATION OF THE NON BIS IN IDEM PRINCIPLE OR SUBSIDIARILY THE EXISTENCE OF MEDIAL CONCURRENCE IN THIS CASE

OPENBANK alleges that it is being subjected to double sanction as a consequence of the same fact and for the violation of the same legal good, considering that it had not established adequate security measures for the transmission (and consequent receipt by it) of what was erroneously considered "financial data" and, at the same time, for not having adopted such measures from the design of the processing.

Likewise, it alleges that, in the denied case that it is not considered that we are facing a double sanction for the same fact, resulting in the violation of the same protected legal good, what cannot be doubted is that the alleged absence of adequate security measures in the sending of the documentation necessarily stemmed from what, in the opinion of the AEPD, was an inadequate risk analysis carried out by OPENBANK, such that it would not have foreseen the implementation of such measures. Thus, if the violation of the non bis in idem principle was denied, there was no doubt about the existence of medial concurrence between both infringements.

OPENBANK cites the proposed resolution of the present sanctioning procedure in which it is expressly stated the following regarding the alleged violation of Article 25 of the GDPR:

“In this protocol, OPENBANK did not foresee offering its clients any communication channel with a high level of security, despite the fact that in clause six of the contract with its data processor it indicates that ‘electronic transfers of Client Information through public or unsecured networks are to be carried out securely using appropriate encryption methods in accordance with Santander Group Policies.’

By applying the aforementioned protocol, OPENBANK places the responsibility for secure communication on the client, who must ensure the confidentiality and integrity of their personal data. At this point, let us remember that, by virtue of the principle of proactive responsibility enshrined in Article 5.2 of the GDPR, the data controller, in this case OPENBANK, is the one who must ensure the effective privacy and integrity of the personal data being processed.”

OPENBANK indicates that the weight of the accusation of the alleged violation of Article 25 of the GDPR falls on the fact that it had not established, in the opinion of the AEPD, “any communication channel with a high level of security,” transferring to the interested party the responsibility of ensuring “the confidentiality and integrity of their personal data.”

That is to say, it is the Proposal for Resolution itself that clearly indicates that the alleged lack of design of adequate technical and organizational measures refers to,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/77

specifically, to the alleged lack of security measures in the sending of the documentation, subsequently making an assessment regarding the alleged ineffectiveness of email encryption to guarantee the integrity and confidentiality of the data.

In this way, it is certainly surprising to OPENBANK that the Proposal for Resolution states in a different place that in the present case there is no reference being made, when discussing the appropriate technical and organizational measures relative to the risk, to the measures related to the sending of the documentation, whose alleged absence has been what led to the communication directed by the claimant to OPENBANK.

In this regard, this Agency reiterates that a new wording will be given to the subsequent legal grounds, as previously indicated.

OPENBANK argues that to support the alleged differentiation and, if applicable, disconnection between both infringements, the AEPD indicates in legal ground III of the Proposal for Resolution that the alleged violation of Article 25 of the GDPR does not refer to the lack of adoption of specific measures in the sending of the documents, but rather to the fact that such measures were not communicated to the claimant when they expressed their concern about the manner of sending them. However, OPENBANK understands that such an argument cannot be sustained, given that this alleged lack of communication stems from the fact that the security measures whose violation is attributed to OPENBANK, and which were subsequently implemented, did not exist at the time the concern was raised to OPENBANK.

That is to say, we would simply be faced with the addition of a new element that does not alter the causal relationship between the infringements attributed to OPENBANK, given that the argument now presented by the AEPD as the basis for the attribution of Article 25 of the GDPR (failure to address the concern expressed by the interested party, to whom, although it may seem otherwise from the reading of the Proposal, a response was indeed given) would stem from the fact that, in the opinion of the AEPD, adequate security measures had not been adopted because, supposedly, OPENBANK had not carried out an adequate risk analysis of the processing for the rights of the interested parties and adopted such technical and organizational measures.

And all of this would bring us back to the initial conclusion already expressed by OPENBANK: a double sanction is being imposed for the same facts and the alleged violation of the same legal good or, at the very least, one of the alleged infringements directly causes and subsumes the other, to the extent that

if this one had not been committed, the second would not have been committed either.

To this effect, OPENBANK indicates that it is paradigmatic to observe how, despite its tireless effort, the Proposal for Resolution merely ratifies what was alleged in the Initiation Agreement, when it states on page 64 of the Proposal the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/77

"From the examination of the proven facts and the documentation in the file, it can be clearly differentiated two infringements based on distinct facts and grounds. The commission of the infringement of Article 32 of the GDPR arises from OPENBANK's request for documentation from clients (and specifically, from the claimant) following the communication protocol established for this purpose, in which no secure means is indicated to the client for providing the requested information. Not even when the client requests an alternative means from the bank, as occurred in the specific case of the claimant, who had no option but to send the aforementioned documentation by email since when approaching OPENBANK to request another option, this did not happen.

Therefore, appropriate technical and organizational security measures were not applied by OPENBANK for the processing in question in general, nor even in response to the request made by the claimant, resulting in data processing (let us remember that data collection is a processing operation according to Article 4.2 of the GDPR) without the adequate security measures to ensure the confidentiality of the processing.

On the other hand, the commission of the infringement of Article 25 of the GDPR is based on the fact that the protocol of OPENBANK in force at the time of the events (in March 2021) did not foresee providing information about the method of sending the requested documentation. The lack of design of an adequate system to comply with the principles of processing, the requirements of the GDPR, and to guarantee the rights of the data subjects is sanctioned."

In other words, Article 32 of the GDPR is considered infringed because "no secure means is indicated to the client for providing the requested information" and Article 25 of the GDPR because OPENBANK's protocol "did not foresee providing information about the method of sending the requested documentation," which is exactly the same as what has just been invoked as the reason for the imputation of Article 32 of the GDPR.

Firstly, this Agency wishes to point out that the infringement of Article 25 of the GDPR and the infringement of Article 32 of the GDPR are infringements that are classified differently as they violate distinct provisions that protect different legal goods, as will be explained below. Therefore, this is something provided for by the legislator, without the violation of one of the provisions preventing the violation of the other, which does not in itself imply a breach of the principle of non bis in idem.

Furthermore, although both infringements are classified as serious for the purposes of prescription in the LOPDGDD, they are referenced in different sections of Article 73 of the LOPDGDD:

"(...)

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the non-integration of the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/77

e) The failure to adopt appropriate technical and organizational measures to ensure that, by default, only personal data necessary for each specific purpose of the processing will be processed, in accordance with the requirements of Article 25.2 of Regulation (EU) 2016/679.

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of the processing, as required by Article 32.1 of Regulation (EU)

2016/679.

g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679. (...)

Therefore, these are perfectly differentiated infringements.

Secondly, Article 31 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, LRJSP) establishes: "Acts that have been sanctioned criminally or administratively shall not be subject to further sanctions, in cases where there is identity of the subject, act, and basis."

In the present case, the infringement for violating the provisions of Article 25 of the GDPR is determined by the inadequate protection of data from design and by default, under which "the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures." These measures do not necessarily have to be strictly security measures, a matter that is specifically addressed in Article 32 of the GDPR concerning the specific processing, whereby "the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk."

Article 25 of the GDPR is violated when those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design have not been adopted, as well as the non-integration of the necessary guarantees in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679, which may occur or not due to the absence or deficiency of security measures. The technical and organizational measures referred to in Article 25 of the GDPR for applying the principles of data protection by design are not limited to strictly security measures. This would simplify the essence and spirit that inspires the GDPR, as well as the legislator's intent, since compliance with the GDPR is not limited to the implementation of technical and organizational security measures; which would mean, in the present case, reducing the guarantee required by Article 25 of the GDPR to its achievement solely with security measures, effectively nullifying the guarantees established by the GDPR.

In this regard, Article 25 of the GDPR states:

"Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/77

freedoms of natural persons, the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement the principles of data protection, such as data minimization, and integrate the necessary safeguards in the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects" (the underlining is ours).

This Agency reiterates that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle. However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk. Of security. Only of security.

Moreover, its objective is to ensure a level of security appropriate to the risk, while in the case of Article 25 of the GDPR, compliance management with the entire GDPR must be guaranteed. Therefore, as can be seen, the two articles pursue different purposes and protect different legal interests, although they may be related.

Regarding the examination of non bis in idem, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) states that:

“(…) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same subject twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the sum of sanctions creates a sanction foreign to the proportionality judgment made by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

But for "bis in idem" to be applicable, there must be a triple identity among the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority judging and irrespective of who the accuser or specific body that has resolved is, or whether it is judged alone or in conjunction with other affected parties.

b) The factual identity implies that the judged facts must be the same, and excludes cases of real concurrence of infringements where there is not a single unlawful act but several.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/77

c) The identity of foundation or causal basis implies that sanctioning measures cannot coexist if they respond to the same nature, that is, if they share the same teleological foundation, which occurs between penal and administrative sanctions, but not between punitive and merely coercive measures. Taking into account the aforementioned in this sanctioning procedure, the principle of non bis in idem has not been violated, since the infringement of Article 25 of the GDPR consists of failing to carry out adequate compliance management, while the infringement of Article 32 of the GDPR pertains to the absence and deficiencies of the security measures (only security) detected, which exist independently of the request made by the complainant. Even if the complainant had not made any request (many other clients may have simply submitted the required documentation without questioning anything), the security measures would be, in themselves, inadequate.

This is in response to the allegations made by OPENBANK, which considers that both provisions require a single conduct, which is to implement adequate security. This is not true, since Article 25 of the GDPR is not limited to ensuring adequate security relative to the risk, but to adopting measures that effectively guarantee the application of data protection principles and compliance with the requirements of the GDPR and protect the rights of data subjects. And this is not only through security measures but also through all types of appropriate technical or organizational measures.

Furthermore, this Agency reiterates what has been stated in the aforementioned resolution proposal. Regarding the infringement of the provisions of Article 25 of the GDPR, it should be noted that Data Protection by Design and by Default (DPbD) is a legal obligation, the violation of which constitutes an infringement as provided in Article 83 of the GDPR.

Data protection by design is part of the compliance management system, which involves conceiving and planning the processing, verifying compliance, and being able to demonstrate it, all framed within a process of continuous review and improvement, where privacy by design plays a fundamental role. Organizations must be concerned with establishing a true culture of data protection within the organization, where data protection is integrated into their compliance policies from the very beginning of the design of personal data processing.

For its part, in the "Privacy by Design Guide" of the AEPD, it is defined as follows: "Privacy by design (hereinafter, PbD) involves using a risk management and proactive responsibility-oriented approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, hardware or software product, service, or process). The lifecycle of the object refers to all stages of...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

which traverses this, from its conception to its withdrawal, passing through the phases of development, production, operation, maintenance, and withdrawal.”

And in the resolution of the sanctioning procedure PS/00001/2021, this Agency has considered that “Proactive responsibility implies the implementation of a compliance and management model for the GDPR that determines the widespread compliance with obligations regarding data protection. It includes the establishment, maintenance, updating, and control of data protection policies in an organization, especially if it is a large company—understood as the set of guidelines that govern the actions of an organization, practices, procedures, and tools—from privacy by design and by default, which guarantee compliance with the GDPR, prevent the materialization of risks, and allow it to demonstrate its compliance.”

In the present case, the lack of design of the processing by OPENBANK is evident, as the activity of collecting customer data has not been included in the so-called “lifecycle of processing” of its Excel file of the data protection impact assessment document (submitted during the trial period of the present procedure); therefore, since this activity was not even foreseen, the risks present in the processing were not identified or evaluated, and appropriate technical and organizational measures have not been applied to effectively implement the principles of data protection (among others, those provided for in Article 5 of the GDPR, relating to confidentiality) and to meet the requirements of the GDPR and protect the rights of the data subjects.

It has also been made clear that the organization did not have an adequate procedure to properly respond to a customer's concern regarding a data protection issue, as in the present case the complainant in their email of July 10, 2021 expressed their disagreement regarding sending data via an unencrypted email. They even indicated that they asked OPENBANK but were not offered another option. Moreover, the complainant provided the solution that was later adopted by OPENBANK, as they stated, “...the bank does not offer the possibility of securely uploading data, for example, through the customer portal (...)”. And they requested that “they check the process from the point of view of data protection and, if applicable, take the appropriate measures.”

However, it was not until the initiation of the present sanctioning procedure that OPENBANK reviewed this issue and adopted a new solution in order to comply with data protection regulations.

Regarding the violation of Article 32 of the GDPR, it is based on the fact that the only communication channel for sending documents offered to customers (including the complainant), as stated in the proven facts, was to reply to the email itself, and that this means of sending was not an appropriate means based on the risk that could exist for the rights and freedoms of the data subjects. In this specific case, OPENBANK did not provide its customer with an appropriate means to submit the documentation, even in light of the warnings from the complainant in this regard, so the sending was done without the appropriate security measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

And this is despite the fact that documents 4 and 5 submitted by OPENBANK along with its allegations, titled “Impact Assessment - Monitoring of Clients and Sensitive Operations,” version August 2021 and October 2022, respectively, in the section “13. Security” have classified the risk as high impact. Furthermore, in the October 2022 version, on page 43, the following indication has been included regarding “Control and residual risk”: “It has been ensured that the communication channels with clients, as a result of matters related to the prevention of money laundering and financing of terrorism, have the necessary technical measures to guarantee the protection of their personal data. Clients will be identified by their ID card and access key to the private client area.”

Subsidiarily, regarding the application of enhanced technical and organizational measures to the treatment in question, it can be stated that the fact that a treatment as a whole is not considered high risk and that a data protection impact assessment does not need to be carried out does not mean that

appropriate security measures should not be applied to the greater risk presented by any of the activities or stages of the treatment in question, in accordance with the provisions of Article 32 of the GDPR. According to OPENBANK's approach, only certain enhanced security measures should be applied to high-risk treatments, but this idea does not correspond with what is established in the GDPR where measures must be appropriate to the risk present in each of the phases of the treatment. In the treatment cycle, which comprises various and distinct activities, not all risks need to be uniform; there may be different levels of risks at the various stages of the treatment, depending on the activities that constitute it. And if there is a higher risk in one phase, even if not all the treatment is of higher risk, appropriate measures should be applied.

Consequently, these are two distinct facts with different legal foundations. In Article 25 of the GDPR, the legal good that is protected is compliance with the GDPR, regarding the obligation to design the treatment in its entirety, identifying and assessing the risks to the rights and freedoms of the data subjects for the purpose of implementing appropriate technical and organizational measures for the effective application of data protection principles, to comply with the management of GDPR compliance; which has not occurred in this case, as the possibility of clients sending the information required under Chapter II of the LPBCFT has not even been evaluated (neither before nor during the treatment) and how to ensure compliance with the provisions of the GDPR. And there was not even a response to the concern, to the problem raised by the claimant regarding the protection of their personal data in this matter. The system did not even have an alarm in place for any issue that could affect the rights and freedoms of clients in terms of data protection, which is a procedure implemented by the data controller that would be activated in the event of any failure of the system itself, whether alerted by a client, by an employee, or detected by the company itself. In this case, it was the submission of documentation with financial data, but it could have been any issue raised in data protection that affected the rights and freedoms of the data subjects. On the contrary, the system limited itself to responding with an automatic reply, without analyzing the substance of what was raised by the claimant and without providing a satisfactory response (that is, without offering an appropriate means to share such information). And the data controller,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/77

OPENBANK also did not take action following the request made by the client, implementing a system that would prevent leaving its clients unprotected when they raised any questions or issues regarding data protection. It should be noted that this is a fundamental right. It concerns risks to the rights and freedoms of the data subjects. It aims to prevent their materialization. If nothing is foreseen, in terms of the preventive risk-based approach established by the GDPR, sooner or later the risk will materialize. For its part, Article 32 of the GDPR refers to the security of processing, that is, to the protection of personal data being processed in terms of the application of measures that ensure a level of security appropriate to the risk, established by the data controller, a provision violated in this case, where processing was carried out by OPENBANK, in which no secure means was provided to the data subject to facilitate the information requested by OPENBANK, which resulted in the specific case of the complainant having to send the requested documentation via a simple email, despite having requested an alternative means from the bank for this purpose, which was not provided. All this despite OPENBANK acknowledging in its documents that it was a risk of "high" impact on the rights and freedoms of the data subjects.

For all the above reasons, this allegation is dismissed.

Regarding the existence of a medial concurrence of infringements, in addition to what has already been stated, this Agency wishes to point out that Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR, given that the GDPR has its own principle of proportionality.

And this is because the GDPR is a closed and complete system.

The GDPR is a European regulation directly applicable in the Member States, which contains a new,

closed, complete, and global system aimed at ensuring the protection of personal data uniformly throughout the European Union.

In relation, specifically and also, to the sanctioning regime provided therein, its provisions apply immediately, directly, and integrally, providing a complete system without gaps that must be understood, interpreted, and integrated absolutely, completely, and integrally, thereby preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data. The opposite would diminish the guarantees of the rights and freedoms of citizens. In fact, a specific example of the absence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Article 83.2 of the GDPR) or which specifies the existing rule regarding a possible medial concurrence (Article 83.3 of the GDPR).

To the above, we must add that the GDPR does not allow for the development or specification of its provisions by the legislators of the Member States, except for what is provided for therein.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/77

The European legislator has specifically provided for this, delimiting it very concretely (for example, the provision of Article 83.7 of the GDPR). The LOPDGDD only develops or specifies certain aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the aim pursued by the European legislator is to establish a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, Recital 2 of the GDPR states that:

“(2) The principles and rules concerning the protection of natural persons with regard to the processing of their personal data must, regardless of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of natural persons.” (the emphasis is ours)

And Recital 13 of the GDPR indicates that:

“(13) In order to ensure a consistent level of protection of natural persons throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including microenterprises and small and medium-sized enterprises, and offers natural persons in all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent sanctions in all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of natural persons with regard to the processing of personal data.” (the emphasis is ours)

In this system, what is decisive in the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR combined with the provisions of Article 83 of the GDPR show the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures referred to in Article 58, paragraph 2, letters a) to h) and j).”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/77

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed alongside the corrective measures or in substitution for them.

And all this with the aim of enforcing compliance with the GDPR, preventing non-compliance, promoting adherence, and ensuring that the infringement is not more profitable than compliance. Therefore, Article 83.1 of the GDPR stipulates that "Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 is in each individual case effective, proportionate, and dissuasive."

Fines must be effective, proportionate, and dissuasive to achieve the purpose intended by the GDPR. For this system to function with all its guarantees, it is necessary that several elements are deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR—or in the LOPDGDD in the Spanish case as permitted by the GDPR itself—whether due to the application of a different media competition than that provided in the GDPR, would undermine the effectiveness of the system, losing its meaning, its teleological purpose, and the will of the legislator, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. And this is because there is no legal gap, there is no supplementary application of Article 29 of the GDPR.

In addition to the above, it should be noted that there is no legal gap regarding the application of media competition. Neither the GDPR allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in case of possible infringement of data protection regulations," Article 63, which opens the Title, states that "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no establishment of a subsidiary application regarding the LRJSP that does not...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
45/77

contains in its provisions any regulation related to any administrative procedure.

Similarly, since the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, given that the GDPR establishes its own, there is no legal gap or subsidiary application of the same; thus, the application of the section related to medial competition is also not applicable for the same reasons.

On its part, regarding the analysis of the specific case subject to this sanctioning procedure, it should be noted that, since Article 29 of the LRJSP is not applicable for the reasons stated, there would also be no medial competition.

Article 29.5 of the LRJSP establishes that "When the commission of an infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

Well, medial competition occurs when, in a specific case, the commission of one infringement is a necessary means to commit another different one.

The established facts determine the commission of two distinct infringements, without the violation of Article 25 of the GDPR, as asserted by OPENBANK, being the necessary means by which the infringement of Article 32 of the GDPR occurs.

It is possible that in the application by the data controller of privacy by design and by default, in order to comply with the requirements of the GDPR and protect the rights and freedoms of the data subjects, incorporating a data protection approach by design and by default, technical and organizational security measures are adopted that do not guarantee an adequate level of security relative to the risk to the rights and freedoms of natural persons.

Conversely, it is possible that a data controller does not conduct an analysis of the measures that ensure the regulatory compliance of the organization, but has adopted security measures that are indeed appropriate, because they serve that purpose and were already implemented.

As previously indicated, in this case, the lack of design of the processing by OPENBANK is evident, since the activity of collecting customer data has not been included in the so-called "life cycle of processing" of its Excel file of data protection impact assessment (provided during the trial period of this procedure); therefore, since this activity was not even anticipated, appropriate technical and organizational measures have not been applied to effectively implement the principles of data protection (among others, confidentiality) and comply with the requirements of the GDPR and protect the rights of the data subjects.

It has also been made clear that the organization did not have an adequate procedure to properly respond to a customer's concern regarding a data protection issue, since in this case the complaining party in their email of July 10, 2021 expressed their disagreement regarding sending data via an unencrypted email. Even indicating that

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
46/77

asked OPENBANK but was not offered another option. Furthermore, the claimant provides the solution that is later adopted by OPENBANK, as it stated, "...the bank does not offer the possibility of securely uploading data, for example, through the client portal (...)" . And it requested that "they check the process from the perspective of data protection and, if applicable, take the appropriate measures."

However, it was not until the initiation of the present sanctioning procedure that OPENBANK reviewed this issue and adopted a new solution in order to comply with data protection regulations.

Regarding the violation of Article 32 of the GDPR, it is based on the fact that the only communication channel for sending documents offered to clients (including the claimant), as stated in the proven facts, was to reply to the email itself, and that this means of sending was not adequate given the risk that could exist for the rights and freedoms of the data subjects. In this specific case, OPENBANK did not provide its client with an appropriate means to submit the documentation, even despite the warnings from the claimant in this regard, so the sending was done without the appropriate security measures. This is despite the fact that documents 4 and 5 submitted by OPENBANK along with its allegations, titled "Impact Assessment - Monitoring of Sensitive Clients and Operations," version August 2021 and October 2022, respectively, in section "13. Security" have classified the risk as high impact.

Furthermore, in the October 2022 version, on page 43, the following indication has been included regarding "Control and residual risk": "It has been ensured that communication channels with clients as a result of issues related to the prevention of money laundering and financing of terrorism have the necessary technical measures to guarantee the protection of their personal data. Clients will be identified by their ID and access key to the private client area."

For all the above reasons, this allegation is dismissed.

FOURTH.- REGARDING OPENBANK'S COMPLIANCE WITH THE PRINCIPLE OF DATA PROTECTION BY DESIGN

OPENBANK argues that:

- Privacy by design refers to the comprehensive analysis of the processing and the risks that it may pose to the rights and freedoms of the data subjects. Thus, this principle could only be considered

violated if it is proven that the sanctioned party did not carry out that process, so the fact that the result of it does not coincide with what the AEPD considers appropriate does not imply a lack of compliance with Article 25 of the GDPR but, if applicable, the infringement of another of its provisions.

The AEPD in its Proposal for Resolution does not even make a minimal assessment regarding this allegation, completely ignoring it, once again trying to link the alleged violation of the principle of privacy by design with the mere fact of not having offered the data subject an alternative means for the submission of documents.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/77

the documents requested by OPENBANK to verify the origin of the funds for three transactions carried out therein, as required by the LPBCFT.

In this regard, this Agency wishes to point out that Article 25 of the GDPR entails not only a "comprehensive analysis of the processing and the risks that it may pose to the rights and freedoms of the data subjects," but also requires that appropriate technical and organizational measures be applied to effectively implement the principles of data protection and integrate the necessary safeguards to meet the requirements of the GDPR and protect the rights of the data subjects. In this sense, Article 73. d) of the LOPDGGD considers a serious infringement for the purposes of prescription "The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the non-integration of the necessary safeguards in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679."

In the present case, it is not only that the data subject (nor the clients in general) was not offered an alternative means for the submission of the documents requested under Chapter II of the LPBCFT, but that the data controller did not foresee such processing, as evidenced in the impact assessment document in force in July 2021 (document submitted during the trial phase of the present sanctioning procedure) in which the aforementioned processing (the sending of such documentation by clients) was not even contemplated. It was only in August 2021 that such processing was incorporated into the follow-up impact assessment of clients, although it was not until October 2022 that the possibility for clients to send documentation through the OPENBANK client area was incorporated, a possibility raised by the claimant as early as July 2021 and which the same 2021 document anticipated as a possibility to be implemented. And this is even without considering that the same 2021 impact assessment considered that the potential impact on the rights and freedoms of the data subjects was high.

OPENBANK also argues that the legal basis III of the Proposal for Resolution adds an additional issue that was not included in the Initiation Agreement and that is now incorporated into it in order to justify the change of approach in the imposition of this sanction: the lack of privacy by design is due to OPENBANK not having foreseen mechanisms that allow for "feedback" on the previously conducted analysis and to take into account the feedback that the data subjects may provide to the data controller.

That is to say, privacy by design not only requires an analysis of the risks arising from the processing which, it must be said, in this case have not materialized in any way, but also requires modifying the circumstances and characteristics of that processing based on the feedback received from the data subjects, so that, in the face of a communication directed to OPENBANK by a specific data subject, Article 25 of the GDPR will only be considered fulfilled if OPENBANK modifies the previously conducted risk assessment and also modifies the technical and organizational measures that the processing entails, even when...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
48/77

such feedback only refers to a supposed potential risk, and never substantiated, mentioned by a single client.

In this regard, this Agency wishes to point out that OPENBANK is correct in stating that data protection by design and by default involves adopting the necessary mechanisms to continuously reevaluate the processing activities carried out, which implies, among other measures, having "mechanisms that allow for 'feedback' on the previously conducted analysis and taking into account the feedback that data subjects may provide to the data controller," where applicable.

Regarding the necessity for the risks arising from the processing to materialize, it is important to highlight that Article 25 of the GDPR does not require such risks to occur; rather, it obliges the adoption of appropriate measures precisely to prevent such risks from materializing.

Finally, this Agency wishes to indicate that it is not intended that a communication made by a specific data subject "will only be considered as fulfilling Article 25 of the GDPR if OPENBANK modifies the previously conducted risk assessment and also modifies the technical and organizational measures that the processing entails, even when such feedback only refers to a supposed potential risk, and never substantiated, mentioned by a single client." However, in this case, there has not even been a proper course of action regarding the issues raised by the complainant, nor has it been substantiated that mechanisms were established to provide them with other means, more suitable based on the existing risk to their rights and freedoms, through which they could provide the requested information. Moreover, in August 2021, the customer follow-up impact assessment document had already indicated that the impact on the rights and freedoms of data subjects was high and that the possibility for clients to provide the requested information through the bank's private area should be implemented. However, it was not until October 2022, more than a year later, that such a possibility was enabled. All of this only serves to demonstrate that OPENBANK did not have a data protection by design and by default approach implemented in its organization, at least concerning the processing subject to this sanctioning procedure.

OPENBANK claims that it had carried out an adequate assessment of the risks arising from the processing, establishing the appropriate measures to mitigate them and even adopting measures related to the issue analyzed in this file prior to the time the complainant contacted it, even if their implementation was subsequent.

And that at the time the events occurred that led to this procedure, OPENBANK had conducted a data protection impact assessment regarding the processing linked to compliance with the due diligence obligations provided for in the LPBCFT. That is to say, it had carried out a detailed analysis of the risks arising from the processing and implemented the appropriate measures to mitigate those risks. In this sense, the fact that the AEPD considers a measure supposedly insufficient cannot imply that it denies that the measures were adopted, as seems to be indicated in the Proposal for Resolution.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
49/77

In this regard, this Agency wishes to point out that Document 4 submitted along with the allegations to the initiation agreement of the present sanctioning procedure indicates that it is dated August 2021, while the first email sent to the complainant is from July 7, 2021. Therefore, this document is subsequent to the claimed facts.

Regarding the risk analysis carried out in the aforementioned document, this Agency reiterates what has already been indicated previously about why Article 25 of the GDPR is considered to have been infringed.

OPENBANK indicates that it has provided the various data protection impact assessments it has carried out in relation to this processing, although it cannot deny its surprise at the fact that the one sent in response to the evidence request made by it does not appear in the administrative file and was attached to the letter sent by OPENBANK to that AEPD on December 19 (page 699 of the administrative file), to which the aforementioned impact assessment is not attached.

In this regard, this Agency wishes to point out that when generating the copy of the file for sending to

OPENBANK, the document with the impact assessment at the time of the events, being an Excel-type file, does not show its content in the generated copy, but it is incorporated in the information systems of this Agency and its content is referenced both in the proven facts and in the legal grounds of this resolution.

OPENBANK also claims that the AEPD seems to deny the validity of the aforementioned documents, even going so far as to refer to qualifying as a "supposed impact assessment" that which anticipated the establishment of mechanisms for the documents to be made available by the interested parties in their private area of the OPENBANK website and App, something that is expressly stated in the assessment carried out by OPENBANK.

At this point, OPENBANK wishes to clarify that the assessments provided (their content, in fact) may not coincide with what that AEPD expects, but they cannot in any way be classified as "supposed" unless the Agency provides evidence that allows such an assertion. OPENBANK understands that the consideration made by that AEPD lacks the slightest foundation and constitutes a serious accusation directed against OPENBANK that, at the very least, should have some support that allows a document adopted by OPENBANK to be converted into a "supposed" document. At the same time, it is difficult to qualify as "supposed" a document that incorporates measures that, with greater or lesser speed, have been effectively implemented by OPENBANK.

In this regard, this Agency wishes to point out that the documents submitted by OPENBANK along with its allegations to the initiation agreement and during the evidence phase of the present sanctioning procedure are not duly signed, making it impossible to verify their authenticity and integrity or guarantee their date. This Agency has also not assessed the content of the aforementioned documents regarding whether they meet the requirements demanded of a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/77

impact assessment of personal data protection in the terms required by the GDPR. Hence the qualification of "assumptions" made by this Agency in its proposal for resolution.

OPENBANK claims that the AEPD does not demonstrate in any way that the risks invoked by it throughout the procedure not only have not materialized, which has never happened, but that they exist in reality, as it focuses its reasoning on the alleged insufficiency of email as a means of communication, despite OPENBANK having already highlighted the validity of this means for the transmission of information.

In this regard, this Agency reiterates that Article 25 of the GDPR does not require that such risks occur; rather, it obliges the adoption of appropriate measures precisely to prevent such risks from materializing.

Similarly, OPENBANK argues that, considering that both the AEPD and the EDPB believe that the assessment of the impact of processing on the rights of data subjects must be a dynamic and successively reviewed process, OPENBANK carried out successive evaluations. However, the AEPD denies any value to the fact that this process involved the subsequent adoption of other complementary measures for the provision of documents, given that the continuous review of processing, defended by the AEPD itself, is now considered by the AEPD a reactive process (even though at the time of occurrence there was no complaint regarding the matter) and constitutes a mere "patch." And if by "patch" it must be understood, according to the Dictionary of the Royal Spanish Academy, as a "provisional solution, and in the long run, unsatisfactory, given to some problem," it seems that this apparently insufficient solution is what the AEPD considers applicable in this case. OPENBANK considers, at this point, that the Proposal for Resolution cannot simultaneously maintain one idea and the contrary with the aim of sanctioning it: it is not possible to say that OPENBANK did not adopt measures from the design to achieve the minimization of the risks of processing through the successive review of the impact assessments carried out in relation to the processing and, at the same time, consider that the measures adopted as a result of that assessment, which coincide with those that the AEPD deems appropriate, are merely a patch, that is, they are not satisfactory to resolve the

alleged problem posed regarding the means used for the sending of documents.

It is also not possible to attribute to OPENBANK that the measures were not implemented "before the system is operational," again referring to the consideration of the implemented measures as a "patch." As already mentioned, OPENBANK is obliged to require its clients to prove the origin of the funds, that is, to put into operation the mentioned "system," at least since the entry into force of the LPBCFT. And at that date, there was no regulation that referred to the principle of privacy by design or to the obligation to carry out an impact assessment on data protection, without prejudice to OPENBANK adopting the technical and organizational measures it deemed appropriate to mitigate any risk that the processing could pose to the right to personal data protection of its clients. The AEPD seems

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/77

consider that OPENBANK should have been aware of a series of obligations that, however, would not be adopted in a legal text until six years after the start of the processing and were not fully applicable until eight years had passed since that date.

OPENBANK considers that it is unreasonable to impose unknown obligations on it or to interrupt compliance processes with anti-money laundering regulations, resulting in non-compliance with that regulation, as a consequence of the entry into force of the GDPR, although in any case it reiterates that it carried out the corresponding data protection impact assessment as well as the adoption of the technical and organizational measures that allowed for the mitigation of any risks arising from the processing.

In this regard, this Agency acknowledges that the use of the term "patch" in its proposed resolution may not have been the most appropriate, which is why a new wording will be provided, which does not prevent this Agency from maintaining that OPENBANK has not implemented data protection by design and by default, regarding the processing subject to this sanctioning procedure, for all the reasons previously detailed extensively. The response has been reactive and not proactive, and generated once the complaint raised by the interested party before the control authority was known.

Finally, this Agency reiterates that while it is true that the approach of the GDPR and the LOPDGDD was completely novel compared to previous data protection regulations, it is equally true that OPENBANK had more than enough time throughout the three years (six years if counted from the adoption of the GDPR text) that elapsed between the approval of the GDPR (April 2016) and its application (May 2018, which granted more than two years for preparation and adaptation to the GDPR) and the facts subject to the complaint that led to this sanctioning procedure (July 2021) to adapt its processing to the provisions of Articles 25 and 32 of the GDPR (four years if considering that measures were only recently adopted for customers to share the requested information through their private area in October 2022).

Of course, it would have been impossible to have a data protection by design approach before carrying out the processing, when it took place many years before the GDPR existed, but it is undeniable that the principle of data protection by design does not imply solely that the measures must be prior to the processing, but that Article 25 of the GDPR itself indicates "both at the time of determining the means of processing and at the time of the processing itself," that is, not only in a prior manner but throughout the duration of that processing and whenever the means of processing are determined, which is a decision that is also made over time, as circumstances and possibilities change.

For all the above reasons, this allegation is dismissed.

FIFTH.- REGARDING THE ALLEGED VIOLATION BY OPENBANK OF ARTICLE 32 OF THE GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/77

It is alleged that the measure adopted by OPENBANK could not be considered contrary to the

provisions established in Article 32 of the GDPR, as the existing measure at the time of the events, namely, the sending of documentation proving the origin of the funds, was adequate in light of the risks that the processing could pose to the rights of the clients.

And that in no case could it be concluded that email was not the appropriate means for carrying out such transmissions, considering what was indicated by the National Cryptologic Center, which, far from deeming the use of email undesirable, highlighted how the main providers of this service had adopted measures aimed at the encryption and authentication of emails.

However, it is acknowledged that the report from the National Cryptologic Center indicated that there are users who make "careless" use of the email service. Nevertheless, it is argued that it is not possible for OPENBANK to adopt the technical and organizational measures applicable to the data processing it carries out based on the more or less careless use that users may make of email services, as this would shift the responsibility for the actions of its clients onto OPENBANK, which cannot be considered in line with the principle of accountability enshrined in our sanctioning regulations.

It is alleged that in response to these arguments, the Proposal for Resolution, despite reproducing the content of the Initiation Agreement in its legal basis VIII, merely rebuts the claims with the categorical assertion that "this Agency does question whether email constitutes a secure means of communication for sending documentation when confidentiality must be guaranteed, as is the case; this is the reason for the imposition of the infringement of Article 32 of the GDPR," subsequently invoking what is stated in the aforementioned report from the National Cryptologic Center.

In this regard, OPENBANK argues that, unless there is an error on its part, in the numerous reports, resolutions, guides, and directives from that AEPD, as well as those issued by the EDPB, there is no indication that would allow OPENBANK to consider that the use of email should be a measure that must be prohibited regarding the receipt of personal data for subsequent processing. There is no doubt that this measure constitutes the usual and customary means of communication between the subjects obliged by data protection regulations, belonging to any sector of activity, and their clients, and yet, it is not known that this has been questioned by that AEPD until the present sanctioning file.

This represents a change in criteria that, at the very least, can be described as surprising for OPENBANK and that, nevertheless, implies the imposition on it of sanctions totaling 2,500,000 euros. And this sanction is imposed based solely on the mere existence of a communication directed to OPENBANK by a client in which there is no evidence of the occurrence, let alone the materialization, of a risk to their right to data protection. Thus, we would be facing what the ruling of the Contentious Chamber indicates.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/77

Administrative Court of the National Audience of December 23, 2022 (appeal 104/2021) qualifies as "a potential infringement that is not penalized by data protection regulations."

In this regard, this Agency wishes to point out that, in the present case, due to the special protection required for the data provided by clients, given the greater risk it posed to their rights and freedoms, as explained in detail previously, reinforced security measures should have been adopted.

In this case, this Agency considers that sending the requested information under Chapter II of the LPBCFT via a simple email was not an adequate measure considering the risk to the rights and freedoms of individuals. This is not only due to the careless use that could be made of email. The aforementioned report from the National Cryptologic Center indicated that some of the measures referenced, adopted by the most well-known email providers, were susceptible to being attacked and that, even if communication were established satisfactorily, the email servers through which the email passes until it reaches its destination would have access to its content. Therefore, it concluded that "it is deduced that it is not sufficient to delegate the security of email to the underlying technologies responsible for delivering it to its recipient."

It was also not foreseen in the client follow-up protocols to provide any type of assistance to the client

for encrypting the documents sent or any other facility, so the information sent via email could also be expected not to have such additional security measure, which is also not widespread among users and requires certain technical knowledge. In this sense, this Agency indicated that making the security dependent on the level of technical knowledge of the client and whether they have the appropriate tools for it represented a transfer of risk from OPENBANK to the client.

Regarding whether OPENBANK should have adopted measures considering the more or less careless use that users might make of email services, this Agency considers that it implies a transfer of risk to OPENBANK due to the actions of its clients, but it is indeed a risk that is more than probable and foreseeable, which OPENBANK should have assessed and attempted to prevent, especially considering that the bank itself assessed that the impact such treatment could have on the rights and freedoms of individuals was high, as stated in the impact assessment of August 2021.

As for the fact that neither in the reports, resolutions, guides, and guidelines of the AEPD nor of the EDPB is there any indication that would allow OPENBANK to consider that the use of email should be a measure that had to be prohibited concerning the receipt of personal data for subsequent processing, it is necessary to recall that it is not the case that sending an email constitutes an unsafe means in any case and regarding any processing, but it is undeniable that in the present case it was not an adequate means to share the information required under Chapter II of the LPBCFT, which required the adoption of reinforced measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/77

Regarding the imposition of a fine of 2,500,000 euros based on a communication directed to OPENBANK by a client in which the materialization of a risk to their right to data protection is not evidenced, this Agency wishes to point out that the infringement of Article 32 of the GDPR, although it was acknowledged as a result of a complaint from an OPENBANK client, it is no less true that the infringement that is established is not only concerning that client but all clients of OPENBANK, given that the only option provided to its clients for sending the documentation requested under Chapter II of the LPBCFT until October 2022 was to send the aforementioned information via a simple email. And regarding the assertion that the risk to their rights and freedoms has not materialized, this Agency indicates that Article 32 of the GDPR does not require such a risk to materialize; rather, it is about adopting appropriate measures to prevent such a risk from materializing. Therefore, this case does not concern "a potential infringement that is not penalized by data protection regulations," but rather it has been established that the measures adopted for sending the documentation requested under Chapter II of the LPBCFT were not appropriate given the greater risk that this information could imply for the rights and freedoms of individuals.

Finally, OPENBANK wishes to clarify that it submitted as Document number 9 along with its written allegations to the Initiation Agreement (page 654 of the administrative file), a certification issued by the Director of Technology and Operations of OPENBANK, which literally stated the following:

"That in accordance with what is defined in the Technological Development Plan of Openbank, as of October 13, 2022, the entity has enabled within the private area of the website (user and password access required) a space for clients to provide the documentation required in compliance with the provisions of Article 6 of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism, whose text reads as follows:

'Article 6. Continuous monitoring of the business relationship.

Obligated subjects shall apply measures of continuous monitoring to the business relationship, including scrutiny of the operations carried out throughout that relationship in order to ensure that they match the knowledge that the obliged subject has of the client and their business and risk profile, including the origin of the funds, and ensure that the documents, data, and information available are up to date."

And that the proposed resolution is limited to indicating that OPENBANK does not evidence the date of the availability of the described procedure to its clients.

In this regard, this Agency wishes to point out that it is certain that as of October 13, 2022, the

possibility for clients to provide the information required under Chapter II of the LPBCFT through their private area of the OPENBANK website was enabled.

SIXTH.- ABOUT THE VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/77

OPENBANK claims that the aggravating factors for the infringement of Article 25 of the GDPR and Article 32 of the GDPR in the proposed resolution contain almost literally the same considerations, which, in its opinion, only highlights the absolute identity of the two behaviors attributed to OPENBANK, thus making the principle of non bis in idem applicable, as previously invoked.

In this regard, this Agency reiterates what it has already stated in its response to the alleged violation of the principle of non bis in idem.

OPENBANK points out that the AEPD considers the sanction to be proportional, given that it is significantly lower than the 885 million euros that constitutes 2% of the turnover of the Santander Group, to which OPENBANK belongs, in the year 2021. To this effect, it invokes the doctrine of the Court of Justice of the European Union regarding the consideration of the term "company," citing various judgments.

However, OPENBANK believes it is necessary to disagree with this consideration, as the AEPD has not demonstrated at any point in the procedure that, beyond holding 100% of OPENBANK's share capital, the Santander Group plays a decisive role in OPENBANK's policies and, even less so, that its actions regarding compliance with data protection regulations (including conducting data protection impact assessments or determining the technical or organizational measures to be adopted in relation to a specific processing) are influenced, even minimally, by the Santander Group. This power of influence is the determining factor used by the jurisprudence invoked in the Proposed Resolution to apply the concept of company established in Union law and, therefore, to calculate the amount of the sanction based on the turnover of the Santander Group and not exclusively of OPENBANK.

In this sense, it is necessary to reiterate that it is the responsibility of the AEPD to prove that power of decision, beyond the ownership of the shareholding, without any evidence having been presented in this regard. On the contrary, as will be evident at first glance by merely consulting their websites, the privacy policies of OPENBANK and the other companies of the Santander Group are different, with OPENBANK having a data protection officer who has no connection with those of the other companies in the Group.

Therefore, it is not appropriate to carry out the calculation established by the Proposed Resolution, which, at most, should be made based on the turnover of OPENBANK, even though OPENBANK is a company that is part of the Santander Group.

On the contrary, as will be evident at first glance by merely consulting their websites, the privacy policies of OPENBANK and the other companies of the Santander Group are different, with OPENBANK having a data protection officer who has no connection with those of the other companies in the Group.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/77

In this regard, this Agency wishes to remind that, as stated in the "2021 Annual Report" of Grupo Santander, Banco Santander S.A. holds 100% of the direct shareholding in OPENBANK, as well as 100% of the voting rights in OPENBANK. Therefore, the decision-making power that Banco Santander S.A. has over OPENBANK is more than decisive; it is absolute. The existence of distinct privacy policies or a data protection officer with no connection to those of the other companies in the Group would not alter this situation.

In this sense, Article 39.1 "Functions of the Data Protection Officer" of the GDPR establishes that:

“1. The data protection officer shall have at least the following tasks:

- a) to inform and advise the controller or the processor and the employees who carry out processing of their obligations under this Regulation and under other Union or Member State data protection provisions;
- b) to monitor compliance with the provisions of this Regulation, other Union or Member State data protection provisions, and the policies of the controller or processor regarding the processing of personal data, including the allocation of responsibilities, awareness-raising and training of staff involved in processing operations, and the corresponding audits;
- c) to provide advice as requested regarding the data protection impact assessment and to monitor its implementation in accordance with Article 35;
- d) to cooperate with the supervisory authority;
- e) to act as a contact point for the supervisory authority on issues relating to processing, including prior consultation referred to in Article 36, and to consult, where appropriate, on any other matter.”

As can be seen, none of these functions refer to the data protection officer having any type of decision-making power, which is logically reserved for the controller of personal data. Therefore, this allegation is dismissed.

OPENBANK claims that the Proposal for Resolution considers that it is not appropriate to take into account the measures adopted to allow the upload of documents related to the origin of funds through the clients' private area, although it does not provide a single argument in this regard.

And that, nevertheless, the AEPD is fully aware that such a measure was already agreed upon as corrective at the time of conducting the data protection impact assessment carried out in August 2021, which is included in the file, although, as the AEPD is well aware, the processes for implementing technical measures within an organization like OPENBANK involve successive processes that take time.

On the contrary, OPENBANK argues that the proposal does not hesitate to consider that the fact that this measure has been adopted must harm or aggravate the conduct of the

57/77

bank, since, surprisingly, the AEPD understands that this corroborates the lack of diligence of OPENBANK, which is incomprehensible to it, as it would disadvantage those who adopt an even more protective process than that required for the benefit of those who take no measures in this regard.

In this respect, this Agency wishes to point out that at the time this sanctioning procedure was initiated (August 26, 2022), even at the signing of the initiation agreement in which the aggravating factors of the violations of Articles 25 and 32 of the GDPR were established (October 3, 2022), OPENBANK had not yet implemented the possibility for clients to provide the requested information under Chapter II of the LPBCFT through their private area of the website, which was only enabled from October 13, 2022, and therefore cannot be considered as a mitigating factor. However, this circumstance has been taken into account when assessing the duration of the violations as well as in deciding not to impose measures that OPENBANK must adopt in this regard.

Regarding the claim that adopting this measure seems to disadvantage the bank, this Agency wishes to reject such assertion. It is not that it disadvantages them, but rather that this Agency considers that the fact that the possibility of implementing such a measure was already requested in the impact assessment document of August 2021, taking into account the potential high impact that such processing could have on the rights and freedoms of individuals, and that it was not until October 2022, more than a year later, that such possibility was implemented, despite the fact that implementation processes require certain timeframes, in the opinion of this Agency, the mentioned timeframes have exceeded what is reasonable and have evidenced a negligent attitude on the part of OPENBANK in this regard.

Finally, this Agency wishes to emphasize that, of course, this criterion in no way “would disadvantage those who adopt an even more protective process than that required for the benefit of those who take no measures in this regard,” but rather, on the contrary, those who did not adopt any measures in this regard would evidently face greater reproach, their attitude would be assessed as even more seriously negligent, the duration of the violation would be greater, and in addition to the fine, measures would be imposed to ensure compliance with the provisions of the GDPR.

Regarding the number of individuals affected by the processing, OPENBANK argues that the Proposal for Resolution contains two paragraphs that cannot be considered, in any way acceptable in terms of their own terms. Indeed, the argument made by the AEPD on this point is, in its entirety, as follows: "OPENBANK qualifies the application of this criterion as 'apriorism lacking the slightest foundation.' However, it is purely logical to consider that a sanction cannot be graduated in the same way when, due to the lack of appropriate measures, the processing potentially affects nearly two million clients, as in the present case. If a small number of individuals who could be potential affected parties were sanctioned in the same way as a large company, then the principle of proportionality would indeed be infringed."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
58/77

Furthermore, OPENBANK alleges that according to the certificate provided by the bank, the number of clients impacted by this type of operation, an average close to 13,000 interested parties in the last two years, confirms that the lack of appropriate technical and organizational measures can put a large number of people at risk, most of whom send personal data related to their assets via email without any measures to protect their confidentiality." OPENBANK indicates that the most basic arithmetic rule allows us to conclude that it is not possible to refer to two million clients and 13,000 (in total, and not as an annual average) as equal or equivalent terms. However, from the reasoning of the AEPD, it seems to be deduced that both terms are equal, given that the reproach included in the Initiation Agreement, which only considered the potential impact on two million clients, is maintained in the proposed Resolution, which, however, seems to consider that 13,000 is the figure that should be taken into account. And it should be noted that the ruling of the National Court of December 23, 2022, already cited, denies the AEPD the capacity to impose sanctions for potential breaches of personal data protection regulations, with the doctrine supported in that ruling being perfectly extrapolable to the present case.

In this regard, this Agency reiterates that in the present case it is not a matter of "potential breaches of personal data protection regulations" but rather that the breaches of Articles 25 and 32 of the GDPR have occurred, even if the risks that these articles aim to prevent have not materialized, which is the purpose of such regulations.

Regarding the number of affected individuals, this Agency will consider that the number of potential affected individuals is the total number of OPENBANK clients (two million clients), who are those from whom the bank could request the required documentation under Chapter II of the LPBCFT, while the number of directly affected interested parties has been 13,000 clients on an annual average, which would give a total of 65,000 clients, considering that there would be 13,000 directly affected clients per year, from May 2018 (when the GDPR came into effect) to October 2022 (when the possibility of submitting documentation through the bank's private web area was enabled), which would be the number of clients that OPENBANK has required to provide documentation under the provisions of Chapter II of the LPBCFT, to whom no appropriate means for submission has been provided.

Regarding the alleged aggravation of the sanction as a consequence of the presumed negligence observed, and aside from the outright denial of the existence of such negligence in its conduct, OPENBANK argues that from what the AEPD has stated, it follows that the existence of intent or negligence in the actions of a data controller or processor must be taken into account to aggravate their responsibility, when in reality this fact cannot simply be considered an aggravating factor, but rather a sine qua non condition to appreciate the concurrence of responsibility, as an essential element for it to be subject to sanctionable reproach for a particular conduct.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
59/77

That is to say, with the reasoning provided by the AEPD, it is concluded that an element which, in any case, must be assessed to appreciate the responsibility of an entity also operates as an aggravating factor. Thus, any violation of data protection regulations is inherently aggravated by the fact that responsibility lies with the accused.

In this regard, this Agency wishes to point out that the negligence observed in OPENBANK's conduct is not the mere negligence required by our legal system as a subjective element of the infringement. Rather, it is a particularly serious negligence, given that the company did not conduct a proper analysis of the risks to the rights and freedoms of the data subjects that could arise from sharing the documentation required under the LPBCFT through a means that was not sufficiently secure, nor were appropriate security measures adopted to provide a means that would not jeopardize the confidentiality of this information. This is true even when a client (as in the specific case of the complainant) requested an alternative means to provide the required documentation; they were neither given a response to their concern nor provided with a secure means of communication for that purpose, nor was there an appropriate course of action taken regarding such a request that would allow for a reevaluation of the adequacy of the means of communication chosen by the entity to share such information.

OPENBANK also claims that the Proposal for Resolution refers to the nature of the data subject to processing as an aggravating circumstance, merely indicating that it does not take into account the fact that such data is classified as "financial data," something that OPENBANK considers to be distorted. However, aside from the nature of such data, what cannot be denied is that the AEPD has considered the infringements referred to in the Proposal for Resolution in light of the nature of the data subject to processing, thereby converting what has been considered an element of the type into an aggravating circumstance, thus violating the most fundamental principles of sanctioning administrative law.

In this regard, this Agency rejects that in the present case the nature of the data subject to processing constitutes an element of the infringing type. The obligation to adopt data protection by design and by default, as well as the obligation to have appropriate security measures based on the risk to the rights and freedoms of natural persons, must be fulfilled regardless of the nature of the data subject to processing. What is true is that in this case, the data in question deserves special protection, which makes applicable the aggravating factor detailed in section g) of Article 83.2 of the GDPR.

Finally, OPENBANK claims that the AEPD takes into account the bank's turnover or business activity on multiple occasions to aggravate the amount of the sanction. Thus, (i) the first circumstance is taken into account to reinforce the potential impact of the facts; (ii) at the same time, regarding negligence, OPENBANK's conduct is aggravated by the understanding that due to its sector of activity, it must be required to exercise special diligence; and (iii) finally, it is considered that OPENBANK's turnover or business activity is linked to the performance of treatments, which should imply this triple aggravation derived from this fact. That is to say, in the opinion of the AEPD, when an entity belonging to the banking sector commits an alleged infringement, its conduct must be...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/77

triple aggravation solely due to the nature of its activity, which can hardly be considered in line with the principle of proportionality.

In this regard, this Agency wishes to point out that it only considers the business or traffic of the bank to aggravate the amount of the sanction concerning the aggravating factor contemplated in Article 76.2 of the LOPDGD, regarding the link between the infringer's activity and the processing of personal data, given that OPENBANK's business activity requires continuous processing of personal data.

However, it is equally true that in assessing the degree of diligence required, the professionalism of the subject is also weighed, so that when the activity of the responsible party involves "constant and abundant handling of personal data," greater diligence is required, in accordance with the provisions of the National Court Judgment of 17/10/2007 (Rec. 63/2006).

IV

Assessment of the evidence presented

The lack of a secure means of sending documentation in the "Protocol for communicating with clients regarding AML/CFT alerts: OPENING AND MANAGEMENT OF GAPS Version of March 2021," argued in the initiation agreement, necessitated the need to verify the effective compliance with the principles of data protection concerning the processing in question, for which it was deemed appropriate to analyze the data protection impact assessment carried out by OPENBANK.

In the course of the allegations to the initiation agreement presented, Document 4.- "Impact Assessment - Monitoring of clients and sensitive operations (August 2021 version)," and Document 5.- "Impact Assessment - Monitoring of clients and sensitive operations (October 2022 version)," were submitted, both documents incorporated into the file of this procedure. However, neither of these documents was in effect at the time the events occurred, as the request made by OPENBANK to the complaining party took place on July 7, 2021. Consequently, it was deemed appropriate to open a period of evidence.

In the document provided by OPENBANK during the evidence period, the collection of data activity when its clients were required to send documentation in compliance with the LPBCFT is not contemplated in its risk assessment, as occurs in the case subject to this sanctioning procedure.

IV

Special protection of the data provided under Chapter II of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism (LPBCFT)

The need for special protection of personal financial data is a criterion shared with the European Data Protection Committee (EDPC), which, in compliance with the objective of ensuring the consistent application of the General Data Protection Regulation (as attributed to it by Article 70 of the GDPR), has developed guidelines to provide a clear and transparent basis for the imposition of sanctions by supervisory authorities.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
61/77

National (Guidelines 04/2022 on the calculation of administrative sanctions under the GDPR).

In section 4.2.3 of the aforementioned Guidelines, the following is stated (unofficial translation):

“Categories of affected personal data

58. Regarding the requirement to take into account the categories of affected personal data (Article 83, paragraph 2, letter g, of the GDPR), the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response in terms of fines. This refers, at a minimum, to the types of data covered by Articles 9 and 10 of the GDPR, and to data outside the scope of these articles whose dissemination causes immediate harm or distress to the data subject (for example, location data, data about private communications, national identification numbers, or financial data, such as transaction summaries or credit card numbers).”

For its part, Article 32 bis of Law 10/2010, added by Article 3.15 of Royal Decree-Law 7/2021, of April 27, requires enhanced measures from the obligated subjects for the processing of personal data related to the scope of application of the regulation:

“... 4. The obligated subjects must carry out a data protection impact assessment of the processing referred to in this article in order to adopt enhanced technical and organizational measures to ensure the integrity, confidentiality, and availability of personal data. Such measures must, in any case, guarantee the traceability of accesses and communications of the data.” (the emphasis is ours)

In compliance with the LPBCFT, obligated entities may process financial data, but not only data of this category; personal data of various natures are also processed: identification, contact, or economic data (business, professional, investment...). Data protection in compliance with the LPBCFT cannot be limited by criteria applicable only to one of these data types when what is being protected is access to the information represented by all these personal data, not only individually but also in their joint processing.

For its part, the “Guidelines on the data protection impact assessment (DPIA) and to determine whether the processing ‘likely results in a high risk’ for the purposes of Regulation (EU) 2016/679,” in what is relevant here, indicate:

“In order to provide a more concrete set of processing operations that require a DPIA due to their inherent high risk (...) the following nine criteria should be considered: 1. Assessment or scoring, including profiling and prediction, especially of ‘aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, the situation or movements of the data subject’ (recitals 71 and 91). Some examples of this may include a financial institution investigating its clients in a credit reference database.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/77

or in a database against money laundering and the financing of terrorism or about frauds...” (the underlining is ours).

The activity carried out by OPENBANK under the provisions of Chapter II of the LPBCFT, whereby clients are requested to provide the “documents that justify a certain income, as they will clarify the origin of the funds that have been deposited in the client's account at OPENBANK” is framed within a financial institution that investigates its clients in a possible database against money laundering and the financing of terrorism, which is why these operations likely entail a higher risk.

And so much so that these operations likely entail a higher risk, that the same LPBCFT deemed it appropriate to incorporate the need to conduct an impact assessment of data protection for the treatments referred to in said article in order to adopt reinforced technical and organizational measures to ensure the integrity, confidentiality, and availability of personal data.

Furthermore, Chapter 9.2 of the Manual on European Legislation on Data Protection, prepared by the European Union Agency for Fundamental Rights, the Council of Europe, the European Court of Human Rights, and the European Data Protection Supervisor, refers to “financial data”: “Although financial data are not considered sensitive data under Convention 108 or the General Data Protection Regulation, their processing requires special guarantees to ensure the accuracy and security of the data. In particular, electronic payment systems need to incorporate data protection measures, that is, privacy or data protection by design and by default.” The mention of privacy protection regarding electronic payment systems highlights their importance, but does not exclude that, similarly, other financial data may require special guarantees, as is the case here with the data collected under the provisions of Chapter II of the LPBCFT.

Regarding the Guide on Risk Management and Impact Assessment in Personal Data Processing by the AEPD, it differentiates between three types of economic data that must be assessed when determining the level of risk of a particular processing for the purpose of conducting the DPIA, distinguishing between these three categories of data:

- Data related to the “[e]conomic situation (e.g., without being exhaustive, personal income, monthly income, assets (movable/immovable property), employment situation).” These data are assigned a “medium risk.”
- Data related to the “[f]inancial status (e.g., without being exhaustive, financial solvency, borrowing capacity, level of debt (personal loans, mortgages), solvency lists, defaults, assets (investment funds, generated returns, shares, accounts receivable, received rents, etc.), liabilities (expenses

for food, housing, education, health, taxes, loan payments, credit cards, or personal expenses, etc.; or debts or obligations).” These data are also assigned a “medium risk.”

- “Payment method data (e.g., without being exhaustive, credit cards and access information to virtual currency services).” In the case of these data, a “high risk” is assigned.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

63/77

The documentation requested by OPENBANK pursuant to the provisions of Chapter II of the LPBCFT, that is, “the documentary support related to the origin of a fund from your bank account (e.g., your payroll, employment contract, purchase agreement if it concerns a real estate transaction, donation or inheritance, the invoice for the services rendered that are paid by the beneficiary of those services, the resolution declaring the receipt of a specific aid, etc.)” contains data related to the economic situation and financial status of clients, which allows for the determination of the financial situation or the asset solvency of a person, and therefore requires greater protection.

The information regarding the origin of the income in clients' bank accounts is information that is closely related to such banking movements and contains data related to the economic situation and financial status of clients, which allows for the determination of the financial situation or the asset solvency of a person, and therefore requires greater protection.

In summary, all of the above implies:

- 1.- That the personal data requested pursuant to Chapter II of the LPBCFT deserves special protection, due to the greater risk it poses to the rights and freedoms of individuals.
- 2.- That the obligated subjects must conduct a data protection impact assessment for this type of processing, in order to adopt reinforced technical and organizational measures to ensure the integrity, confidentiality, and availability of personal data.

VI

Data Protection by Design and by Default

Article 25 “Data Protection by Design and by Default” of the GDPR establishes:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of individuals, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of their processing, the duration of their storage, and their accessibility.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

64/77

These measures will ensure, in particular, that, by default, personal data is not accessible, without the intervention of the individual, to an indeterminate number of natural persons.

3. An approved certification mechanism under Article 42 may be used as an element that certifies compliance with the obligations established in paragraphs 1 and 2 of this article.”

This article falls within the general obligations that Chapter IV of the GDPR establishes for the data controller, imposing a design obligation at the time of determining the means of processing, which must effectively ensure compliance with the principles of data protection.

In this case, the lack of design of the processing by OPENBANK is evident, as the activity of collecting customer data has not been included in the so-called "lifecycle of processing" in its Excel file of the data protection impact assessment document (submitted during the trial period of this procedure) in force at the time of the claimed facts; therefore, since this activity was not even foreseen, appropriate technical and organizational measures have not been applied to effectively implement the principles of data protection (among others, confidentiality) and comply with the requirements of the GDPR and protect the rights of the data subjects.

Regarding the analyses carried out by OPENBANK in the documents titled "Impact Assessment - Monitoring of Clients and Sensitive Operations," in its version of August 2021, which was not even in force at the time of the events subject to the complaint, which took place in July 2021, it was only foreseen as a possibility that clients would send the information via encrypted message, sending the password through another channel. Even in the aforementioned document, it is mentioned that "an internal request has been made for data subjects to be able to upload documents directly through the website section, once they have logged in." However, it has been verified that the complainant was never given that possibility, neither in the initial communication sent by OPENBANK nor subsequently when they requested a secure alternative way to send that communication. It was also verified that in the communication model sent to clients, none of these options were provided; it only mentioned the possibility of replying to the email sent without giving further indications on how that information could be protected.

It is curious that, despite not providing any sufficiently secure means for its clients to provide the information they were obligated to, both documents in their 2021 and 2022 versions acknowledge that the inherent risk of such processing was of high impact on the rights and freedoms of the data subjects.

And yet, it is only in the version of October 2022 that OPENBANK indicates that "clients will be identified by ID card and access key to the private client area."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
65/77

What is certain is that the communication directed to the client complied with the provisions in the document provided by OPENBANK as a protocol for requesting documentation from clients under the LPBCFT, and the communication directed to the clients did not indicate any means to provide that information, beyond the possibility of responding to the aforementioned email.

In any case, to comply with data protection by design and by default, it is not sufficient to merely have a protocol document or a model communication, if upon reviewing such documents it is found that there was no proper consideration regarding the appropriate technical and organizational measures to effectively apply the principles of data protection and integrate the necessary guarantees in the processing in order to meet the requirements of the GDPR and protect the rights of the data subjects, as provided in Article 25.1 of the GDPR.

It is also not sufficient to have documents that establish protocols or models to follow, if then in practice, when carrying out the processing, appropriate measures are not provided to apply the principles of data protection nor are the necessary guarantees integrated to comply with the requirements of the GDPR.

In the present case, it has been established that in the impact assessment in effect at the time of the claimed events, the processing of the data provided by the clients under the provisions of Chapter II of the LPBCFT was not even contemplated. And that in July 2021, the claimant was requested to send certain information, which could have a high impact on their rights and freedoms, via email, without being given further instructions on how to send such information through a secure channel.

It has also been established that the claimant had expressed their concern to the bank in this regard

and had requested that a secure means be provided to share such information. However, faced with the bank's refusal, they had no choice but to send the requested information via a simple email, to their dismay and despite having expressed their reservations. The claimant even expressly requested that their concern be taken into account and that a secure means be enabled in the future to share this type of information.

However, in the documents from August 2021 that OPENBANK submitted along with its allegations to the initiation agreement, no other means is provided either.

From the content of the documentation in the file, it has been established:

- That in the "Annex I - Communications to clients to request information and/or documentation for PBC" of the document "PROTOCOL OF COMMUNICATIONS TO CLIENTS FOR PBC/FT ALERTS: OPENING AND MANAGEMENT OF GAPS", dated March 2021, in the first communication directed to the client, in which they are requested to prove the origin of the funds, no specific means is provided by which they must provide such information to OPENBANK. And that in the second communication directed to the client, no means is provided either by which to provide such documentation to the bank, but

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
66/77

The text includes the threat that if the requested documentation is not received within the next 15 days, OPENBANK may prevent new deposits into the accounts.

-

On July 7, 2021, OPENBANK requested that the claimant send documentation proving the origin of certain funds, under the threat that new deposits could be prevented in 15 days, without indicating any means by which such information should be provided.

-

On July 10, 2021, the claimant provided the requested documentation, expressing their disagreement because when they inquired about how to send such information, they were told to do so via email, without further instructions. In this email, the claimant indicates that they do not consider it a secure means, that they are using this method because they felt compelled to do so, and even provide as an example of a secure means the possibility of sending it "through the client portal," a possibility that was not offered to them by OPENBANK. They also request that the process be checked from the perspective of data protection and that appropriate measures be taken. However, this email only received an automatic acknowledgment of receipt from the bank on July 13, 2021.

-

In the document "Impact Assessment - Monitoring of Clients and Sensitive Operations," dated August 2021, it is provided that the interested party can respond to the email with an encrypted message, sending the password through another channel. It has also been requested that this could be done directly through the website section, once logged in.

-

In the document "Impact Assessment - Monitoring of Clients and Sensitive Operations," dated October 2022, it is provided that clients will authenticate themselves using their ID and access key to the private client area.

-

In the document "PROTOCOL FOR COMMUNICATIONS TO CLIENTS REGARDING TRANSACTIONAL MONITORING ALERTS FOR THE PREVENTION OF MONEY LAUNDERING AND TERRORISM FINANCING (AML/CFT)," dated October 2022, it is indicated that clients will be informed to upload the documentation through the private area of the OPENBANK website. In "Annex I - Communications to Clients to Request Information and/or Documentation Due to a Transactional Monitoring Alert for AML/CFT," it is indicated to the client to send the documentation through the "Client Area" of the OPENBANK website.

That is to say, the protocol in force at the time of the events (from March 2021) did not foresee

providing information about the method of sending the requested documentation.

In July 2021, the claimant drew attention to this issue in the email sent on July 10, 2021, to OPENBANK. However, the bank ignored this and did not even respond to their concern, which clearly related to a matter of personal data protection, which also evidences the lack of an internal procedure at OPENBANK to channel these issues.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
67/77

In August 2021, OPENBANK foresees the possibility for customers to send the referred documentation via an encrypted email, providing the password through another email (without specifying which one). It is indicated that the possibility was requested for this documentation to be provided through the customer area of the OPENBANK website.

It is not until October 2022 that the communication protocols and the documents of the supposed impact assessment of this issue specifically incorporate that customers can submit the requested documentation through the OPENBANK website by logging into their customer area.

That is to say, the solution to provide this information through the customer area was adopted a year and a half later than the action protocol adopted in March 2021 and more than a year later than the claimant had drawn attention to this specific issue, and that the document of the supposed impact assessment of this issue had already anticipated it as a possibility that needed to be followed up. All of this evidences that OPENBANK did not apply a data protection by design approach either before or during the processing of the data.

In Article 25 of the GDPR, the legal good that is protected is compliance with the GDPR, regarding the obligation of designing the processing in its entirety, identifying and assessing the risks to the rights and freedoms of the data subjects for the purpose of implementing appropriate technical and organizational measures for the effective application of the principles of data protection, in order to comply with the management of GDPR compliance; which has not occurred in this case, as the possibility for customers to send the required information under Chapter II of the LPBCFT was not even evaluated (neither before nor during the processing) and how to ensure compliance with the provisions of the GDPR. And there was not even a response to the concern raised by the claimant regarding the protection of their personal data in this matter. The system did not even have a provision for an alert regarding any issue that could affect the rights and freedoms of customers in terms of data protection, that is, a procedure that would be initiated in the event of any failure of the system itself. On the contrary, the system merely responded with an automatic reply, without analyzing the substance of what was raised by the claimant and without providing a satisfactory response (that is, without offering an appropriate means to share such information).

Therefore, in the present case, it is not only that an alternative means for the submission of the documents requested under Chapter II of the LPBCFT was not offered to the interested party (or to customers in general), but that in the impact assessment document in force in July 2021 (document submitted during the trial phase of this sanctioning procedure), the aforementioned processing (the sending of such documentation by customers) was not even contemplated. And it was only in August 2021 that such processing was incorporated into the follow-up impact assessment of customers, although it was not until October 2022 that the possibility for customers to send documentation through the customer area of OPENBANK was incorporated, a possibility raised by the claimant already in July 2021 and that the same document from 2021 anticipated as a possibility to be implemented.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
68/77

and this is not even taking into account that the impact assessment of 2021 considered that the possible impact on the rights and freedoms of the interested parties was high.

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to OPENBANK for violation of Article 25 of the GDPR.

VII

Qualification of the infringement of Article 25 of the GDPR

The aforementioned infringement of Article 25 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

For the purposes of the limitation period, Article 73 "Serious infringements" of the LOPDGDD indicates:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a limitation period of two years, which involve a substantial violation of the articles mentioned therein and, in particular, the following: (...)

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the non-integration of the necessary safeguards in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679. (...)"

VIII

Sanction for the infringement of Article 25 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

69/77

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (section a): For failing to implement appropriate technical and organizational measures that ensure the effective application of personal data protection principles and integrate the necessary safeguards to comply with the requirements of the GDPR and protect the rights of two million potentially affected customers and 65,000 directly affected customers, at least from May 2018 to October 2022. Section 54.b.iv of the EDPB Guidelines 04/2022 states, as one of the circumstances to be considered in the assessment of the sanction: "The number of specifically, but also potentially affected parties," and clarifies regarding this criterion: "The higher the number of affected parties involved, the greater weight the supervisory authority may attribute to this factor. In many cases, it may also be considered that the infringement assumes 'systematic' connotations and, therefore, may affect, even at different times, additional data subjects who have not lodged complaints or reports with the supervisory authority. The supervisory authority may, depending on the circumstances of the case, consider the relationship between the number of affected parties and the total number of parties in that context (for example, the number of citizens, customers, or employees) in order to assess whether the infringement is systemic in nature."

- The intentionality or negligence in the infringement (section b): OPENBANK has been severely

negligent, as the company did not conduct a proper analysis on how to effectively apply the principles of data protection and integrate the necessary safeguards in sending the documentation requested from customers under the LPBCFT, in order to comply with the requirements of the GDPR and protect the rights of the data subjects, not even when a customer (as in the specific case of the claimant) drew attention to this issue, nor was there an appropriate course of action taken regarding such a request that would allow for a reevaluation of the adequacy of the communication method chosen by the entity to share such information. Regarding the degree of diligence that the data controller is obliged to exercise in fulfilling the obligations imposed by data protection regulations, the Judgment of the National Court of 17/10/2007 (Rec. 63/2006) can be cited. Although it was issued before the GDPR came into force, its pronouncement is perfectly extrapolable to the case at hand. The aforementioned Judgment, after referring to the fact that entities whose activities involve continuous processing of data from customers and third parties must observe an adequate level of diligence, specified that "(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

70/77

- The categories of personal data affected by the infringement (section g): In this case, it is requested to prove the origin of several amounts received in the account of the interested party, which implies a greater risk to the rights and freedoms of the data subject, thus these are data that deserve special protection.

It is also considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As an aggravating factor:

- The link between the infringer's activity and the processing of personal data (section b): The development of the business activity carried out by OPENBANK requires continuous processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating what is established in Article 25 of the GDPR, allows for the imposition of a sanction of €1,500,000 (one million five hundred thousand euros).

IX

Security Measures

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to

the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.” In this case, neither in the protocol of March 2021 nor in the email sent by OPENBANK to the claimant on July 7, 2021, was any means of communication indicated for sending the documentation requested by OPENBANK. The only communication channel for sending documents was to reply to the email itself, as no other was offered to the client.

In this specific case, OPENBANK did not provide its client with an appropriate means to submit the documentation, even despite the warnings from the claimant in this regard, so the submission was made without adequate security measures.

This is despite the fact that documents 4 and 5 submitted by OPENBANK along with its allegations, titled “Impact Assessment - Monitoring of Clients and Sensitive Operations,” version August 2021 and October 2022, respectively, in section “13. Security” have classified the risk as high impact. Only in the October 2022 version, on page 43, was the following indication included regarding “Control and residual risk”: “It has been ensured that communication channels with clients concerning matters related to the prevention of money laundering and terrorist financing have the necessary technical measures to guarantee the protection of their personal data. Clients will be identified by their ID and access key to the private client area.”

In this regard, email cannot be considered an appropriate means to ensure a level of security adequate to the risk in the sending of documentation containing personal data provided under Chapter II of the LPBCFT, which requires special protection, taking into account the regulations on the prevention of money laundering, the nature of the data being processed, and the GDPR.

Regarding the security of email, the “Good Practices Report” of May 2021, CNN-CERT BP02, from the National Cryptologic Center, a service attached to the National Intelligence Center, whose mission is to contribute to the improvement of Spanish cybersecurity, outlines a series of vulnerabilities of email and the various ways in which they can be attacked, as well as security recommendations. In section 4.2 of this Report, the “Security of communications via email” is described, with the following assertions on pages 37 to 39:

“The protocol involved in this sending process is SMTP. This protocol has been used since 1982 and when it was implemented, security measures were not taken into account.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

72/77

of security such as encryption or authentication of communications. This means that the entire sending process described above would be carried out in plain text, meaning that at any point in the transmission, an attacker could see and manipulate the content of the emails. Due to these shortcomings in SMTP, various technologies and extensions have been developed that allow for the incorporation of security measures to ensure authentication, integrity, and encryption of email communications. Some of the most well-known technologies are STARTTLS, SPF, DKIM, and DMARC... Although well-known email providers such as Google, Yahoo, and Outlook encrypt and authenticate emails using these types of technologies, many organizations continue to use email carelessly. It should also be noted that these technologies must be implemented both at the source and at the destination for them to be utilized. Furthermore, some of these measures are susceptible to attacks. For example, STARTTLS is vulnerable to downgrade attacks, where an attacker in a man-in-the-middle situation can force the TLS negotiation not to take place (it would be sufficient to

replace the STARTTLS string).

Even in the case that TLS communication is successfully established, the mail servers through which the email passes until it reaches its destination would have access to its content. Due to these facts, it is concluded that it is not sufficient to delegate the security of email to the underlying technologies responsible for delivering it to its recipient.

In light of the aforementioned security shortcomings, the need to adopt reinforced measures to appropriately ensure the integrity and confidentiality of personal data sent by email is evident, especially when communicating personal data that deserves special protection, as in the present case, measures that have not been applied, which has posed a greater risk for OPENBANK clients sending personal data through this medium.

It should be noted that the GDPR does not establish a list of security measures applicable according to the data being processed, but rather, under the principle of proactive responsibility of Article 5.2 of the GDPR itself, which entails the requirement that the data controller ensures the effective privacy and integrity of the data, both the controller and the processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of probability and severity for the rights and freedoms of the data subjects.

Moreover, the controller must be in a position to demonstrate that it has implemented those measures and that they are adequate to achieve the intended purpose.

Additionally, the security measures must be appropriate and proportionate to the identified risk, indicating that the determination of the technical and organizational measures should be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (not audit), evaluation, and assessment of the effectiveness of the measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

73/77

In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by data processing, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the risks inherent in the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the costs of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial harm.”

In light of the above, the technical and organizational measures applied by OPENBANK in the request for information from its clients (specifically from the claimant) in compliance with anti-money laundering regulations did not guarantee an adequate level of security commensurate with the risk, as required by Article 32 of the GDPR, due to the nature of the personal data being processed, which deserves special protection regarding its confidentiality and integrity.

Subsidiarily, regarding the application of enhanced technical and organizational measures to the processing in question, it can be stated that the fact that a processing operation as a whole is not considered high risk and that a data protection impact assessment does not need to be carried out

does not mean that appropriate security measures should not be applied to the risk presented by any of the activities or stages of the processing in question, in accordance with the provisions of Article 32 of the GDPR.

In the processing cycle, which includes various and distinct activities, not all risks need to be uniform; there may be different levels of risks at different stages of the processing, depending on the activities that constitute it. And if there is a high risk in one phase, even if not all processing is high risk, appropriate measures should be applied.

In accordance with the evidence available at this moment in the resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement attributable to OPENBANK for violation of Article 32 of the GDPR.

X

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

74/77

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

For the purposes of the limitation period, Article 73 “Serious infringements” of the LOPDGDD indicates:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a limitation period of two years, which involve a substantial breach of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

XI

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the resolution of the sanctioning procedure, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm suffered (paragraph a): For not having an appropriate means for sending the documentation requested under the LPBCFT, from May 2018 to October 2022, directly affecting the rights and freedoms of 65,000 individuals and potentially affecting two million clients.

Paragraph 54.b.iv of the Guidelines 04/2022 of the EDPB includes, as one of the circumstances to be assessed in the grading of the sanction: “The number of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

75/77

specifically interested parties, but also potentially affected,” and clarifies regarding that criterion: “The

higher the number of interested parties involved, the greater weight the supervisory authority may attribute to this factor. In many cases, it may also be considered that the infringement assumes 'systematic' connotations and, therefore, may affect, even at different times, additional data subjects who have not lodged complaints or reports with the supervisory authority. The supervisory authority may, depending on the circumstances of the case, consider the relationship between the number of affected interested parties and the total number of interested parties in that context (for example, the number of citizens, clients, or employees) in order to assess whether the infringement is of a systemic nature."

-

Intentionality or negligence in the infringement (section b): OPENBANK has been severely negligent in determining the means of sending the documentation required to clients under the LPBCFT, as the company did not adopt appropriate security measures based on the risk to the rights and freedoms of individuals, not even when a client (as in the specific case of the claimant) raised this issue, nor even when its own impact assessment document indicated the need to send the information requested under the LPBCFT through the private area of the bank's website and indicated that it was a high-impact processing for rights and freedoms. Regarding the degree of diligence that the data controller is obliged to exercise in fulfilling the obligations imposed by data protection regulations, the Judgment of the National Court of 17/10/2007 (Rec. 63/2006) can be cited. Although it was issued before the entry into force of the GDPR, its pronouncement is perfectly extrapolable to the case at hand. The aforementioned Judgment, after referring to the fact that entities whose activities involve continuous processing of data from clients and third parties must observe an adequate level of diligence, specified that "(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on rigor and exquisite care to comply with the legal provisions in this regard." Due to the high impact that this could entail for the interested parties, OPENBANK was obliged to find solutions that did not pose a greater risk to the rights and freedoms of its clients and that guaranteed data security.

-

The categories of personal data affected by the infringement (section g): In this case, it is requested that the origin of several amounts received in the interested party's account be proven, which, by providing that information without adequate security measures, could increase their vulnerability to potential attacks, which implied a greater risk to the rights and freedoms of the data subject.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

76/77

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As an aggravating factor:

- The connection of the infringer's activity with the processing of personal data (section b): The development of the business activity carried out by OPENBANK requires continuous processing of personal data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of a sanction of €1,000,000 (one million euros).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on OPEN BANK, S.A., with NIF A28021079, a fine of €1,500,000.00 (ONE

MILLION FIVE HUNDRED THOUSAND EUROS) for the infringement of Article 25 of the GDPR and a fine of €1,000,000.00 (ONE MILLION EUROS) for the infringement of Article 32 of the GDPR, both classified under Article 83.4 of the GDPR.

SECOND: TO NOTIFY this resolution to OPEN BANK, S.A.

THIRD: To warn the sanctioned party that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the infringer, the infringement committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-010623

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es